

Ain Shams University
Faculty of Engineering
Computer Engineering and Software Systems



CFI - Care: Collaborative Flow of Intelligence for Care

Graduation Project Thesis

Author: Mohamed Salah Fathy 21P0117
Youssef Tamer Hossam 21P0138
Salma Hisham Hassan Wagdy 21P0124
Salma Mohamed Abdelmonem 21P0148
Belal Anas Awad 21P0072
Supervisors: Dr Haitham Azmi

Submission Date: 04 April, 2025

Mohamed Salah Fathy 21P0117
Youssef Tamer Hossam 21P0138
Salma Hisham Hassan Wagdy 21P0124
Salma Mohamed Abdelmonem 21P0148
Belal Anas Awad 21P0072
Date: 04 April, 2025

Abstract

Healthcare today is characterized by fragmented experiences where patient medical information is often dispersed across various institutions and providers. This project proposes a comprehensive, patient-centric healthcare application designed to consolidate all medical reports into a single, secure, and unified platform. The system employs Role-Based Access Control (RBAC) to ensure privacy and controlled information sharing. To enhance clinical decision-making, the platform features a medical history visualization graph for tracking health trends and integrates a Retrieval-Augmented Generation (RAG)-enabled AI model to generate diagnostic reports and insights. By transforming isolated data into an interconnected ecosystem, this project aims to establish meaningful relationships between patients, caregivers, and doctors for personalized healthcare delivery.

Contents

1	Introduction	1
1.1	Digital Health Market Overview	3
1.2	HL7 - Health Level Seven	3
1.2.1	Evolution of Standards	3
1.3	Fast Healthcare Interoperability Resources (FHIR)	4
1.3.1	Core Architecture	4
1.3.2	Key Technical Advantages	4
1.3.3	Comparison of Standards	5
2	Literature Review	7
2.1	Authentication and Authorization Standards	7
2.1.1	OAuth 2.0 and OIDC	7
2.1.2	JSON Web Tokens (JWT)	7
2.1.3	PKCE	7
2.2	Healthcare Security and Standards	7
2.2.1	FHIR and SMART on FHIR	7
2.3	Token-Based Authentication Patterns	8
2.3.1	Session Management	8
2.4	API Security	8
2.4.1	Rate Limiting	8
2.4.2	Input Validation and XSS	8
2.4.3	CSRF	8
2.5	Mobile Application Security	8
2.5.1	Secure Token Storage	8
2.6	Audit Logging and Compliance	8
2.6.1	Security Event Logging	8
2.6.2	Threat Modeling	9
2.7	Infrastructure and Deployment	9
2.7.1	API Gateway	9
3	Proposed Design Architecture	10
3.1	System Architecture	10
3.1.1	High-Level Architecture	10
3.1.2	Node.js Application Server	11

3.1.3	Data Persistence and Schema	12
3.1.4	Request/Response Flow and Data Transformation Pipeline	14
3.1.5	Error Handling and Fault Tolerance	19
3.1.6	Security and Infrastructure Layer	21
3.1.7	HAPI FHIR Server Implementation	21
3.2	API Design and Endpoints	22
3.2.1	RESTful Structure and Formats	22
3.2.2	FHIR-Compliant Endpoints	22
3.2.3	Custom History Graph Endpoints	22
3.3	Patient History Graph Implementation	23
3.3.1	Motivation: Beyond Linear Medical Records	23
3.3.2	Graph Data Model	25
3.3.3	Graph Construction Algorithm	25
3.3.4	Temporal Branching and Concurrent Episodes	27
3.3.5	Relationship Classification	28
3.3.6	Handling Edge Cases	29
3.3.7	Query Patterns and Optimization	29
3.4	Performance Optimization	30
3.4.1	Tier 1: Standard Resource Cache	31
3.4.2	Tier 2: Specialized Graph Cache	33
3.5	Frontend	36
3.6	Mobile	36
4	Security	37
4.1	Introduction	37
4.2	Architecture & Design	37
4.2.1	Identity & Access Management	39
4.2.2	Authorization & Policy Enforcement	43
4.2.3	Doctor–Patient Consent & Access Grants	43
4.2.4	Session Management & Revocation	44
4.2.5	Defense-in-Depth	46
4.3	Implementation & Setup	47
4.3.1	Keycloak Configuration	47
4.3.2	Backend-for-Frontend (BFF) Security Implementation	48
4.3.3	nginx API Gateway	49
4.3.4	Container Security & Deployment	50
4.3.5	Frontend & Mobile Clients	50
4.3.6	Angular Frontend Security Implementation	53
4.3.7	Keycloak	54
4.3.8	Redis	54
4.3.9	nginx API Gateway	54
4.3.10	PostgreSQL	54
4.3.11	Node.js Backend-for-Frontend (BFF) Libraries	55
4.4	Challenges & Trade-offs	55

4.4.1	Session Management Across Client Types	55
4.4.2	Stateless Tokens vs. Revocation Needs	55
4.4.3	Balancing Consent Privacy & Usability	56
4.4.4	Clock Skew & Distributed Verification	56
4.5	Security Analysis	56
4.5.1	Attack Surface Analysis	56
4.5.2	Threat Model & Residual Risks	57
4.5.3	Mitigations Implemented & Gaps	57
4.6	Summary	58
5	AI Integration	60
6	Testing and Verification	61
6.1	Backend Testing Overview	61
6.1.1	Execution Environment	61
6.1.2	Scope	61
6.1.3	API Route Coverage	61
6.1.4	Service and Integration Tests	62
6.1.5	Test Design and Data	62
6.1.6	End-to-End Workflows	62
6.1.7	Validation and Middleware	63
6.1.8	Caching and Redis	63
6.1.9	Database Checks	63
6.1.10	Gaps and Next Steps	63
6.1.11	Test Result Summary	63
6.1.12	Interpretation of Results	63
7	Conclusion and Future Work	65
7.1	Conclusion	65
7.2	Future Work	65
7.2.1	Security	65
	Appendix	66
A	Lists	67
	List of Abbreviations	67
	List of Figures	69
	References	70

Chapter 1

Introduction

Today, patients often face fragmented healthcare experiences, with their medical information dispersed across multiple institutions and providers. This project proposes a patient-centric healthcare application designed to consolidate all medical reports within a single, secure, and unified platform.

The system empowers patients to manage their health through continuous data collection, secure communication, and controlled information sharing using Role-Based Access Control (RBAC) to ensure privacy, consent, and data integrity. Additionally, by integrating features such as medical history visualization and Retrieval-Augmented Generation (RAG)-enabled AI, the proposed system transforms previously scattered and isolated medical data into a unified, interconnected ecosystem. This integration establishes meaningful relationships between patients, healthcare providers, and medical records, promoting continuous, coordinated, and personalized healthcare delivery.

Purpose

The primary purpose of this project is to develop a unified healthcare platform that securely consolidates patients' medical records from multiple institutions. By leveraging technologies such as RAG-enabled AI and graphical data visualization, the project aims to enhance clinical insight and support medical decision-making. Furthermore, the platform seeks to empower patients to monitor their own health data while maintaining full control over information sharing through robust RBAC mechanisms. Ultimately, this initiative strives to ensure privacy, data integrity, and interoperability across the healthcare ecosystem to enhance patient trust and system reliability.

Objective

The key objectives of this project are as follows:

- To develop a unified healthcare platform that securely consolidates patients' medical records from multiple institutions.
- To empower patients to manage and monitor their own health data while maintaining full control over information sharing through RBAC mechanisms.
- To enable secure and efficient communication between patients, doctors, and caregivers.
- To provide data visualization tools, including a medical history graph, to help healthcare providers interpret patient data trends and clinical progress.
- To integrate RAG-enabled AI capabilities to generate automated reports and actionable insights that support doctors in diagnosis and medical decision-making.
- To ensure privacy, data integrity, and interoperability across the healthcare ecosystem to enhance patient trust and system reliability.
- To implement a defense-in-depth security architecture leveraging OAuth 2.0, JWT, and FHIR Consent resources for multi-layered authentication, authorization, and access control across browser and mobile clients.
- To establish comprehensive audit logging, session management, and revocation capabilities for forensic analysis and immediate access termination.

1.1 Digital Health Market Overview

The global push towards digital transformation in healthcare is driven by the need for efficiency, accessibility, and improved patient outcomes. According to Grand View Research, the global digital health market size was valued at USD 288.55 billion in 2024 and is projected to reach USD 946.04 billion by 2030, expanding at a Compound Annual Growth Rate (CAGR) of 22.2% from 2025 to 2030 [1].

This rapid growth is fueled by factors such as the increasing penetration of smartphones, advancements in internet connectivity, and government initiatives promoting digital health infrastructure [1]. However, realizing this potential requires overcoming the challenge of data silos. Currently, healthcare data is often locked within proprietary systems, making *interoperability*—the ability of different information systems to access, exchange, integrate, and cooperatively use data in a coordinated manner—a critical requirement for the modern healthcare ecosystem [3].

1.2 HL7 - Health Level Seven

Health Level Seven (HL7) International is a standards development organization that has defined the framework for the exchange, integration, sharing, and retrieval of electronic health information for decades [2]. Understanding the evolution of these standards is crucial to appreciating the architectural shifts in modern healthcare applications.

1.2.1 Evolution of Standards

- **HL7 v2 (The Workhorse):** Established in 1989, HL7 v2 remains the most widely implemented standard for hospital workflows (e.g., ADT - Admission, Discharge, Transfer messages). It utilizes a non-XML, pipe-delimited syntax (e.g., MSH|^~\&|...). While highly efficient for legacy backend systems, its lack of semantic strictness leads to significant implementation variances, posing challenges for modern web and mobile application development [2].
- **HL7 v3 (The Theoretical Model):** Introduced in the 1990s to address the vagueness of v2, HL7 v3 was built on a rigorous Reference Information Model (RIM). It enforced strict semantic correctness using complex XML structures. However, this theoretical purity resulted in a steep learning curve and bloated message sizes, leading to poor adoption rates and a lack of backward compatibility with v2 [2].
- **HL7 CDA (Clinical Document Architecture):** A component of v3, CDA focuses on the exchange of clinical documents (such as discharge summaries). While effective for static snapshots of care, it is document-centric rather than data-centric, making it difficult to extract granular data (like a single heart rate reading) required for real-time interactive applications [4].

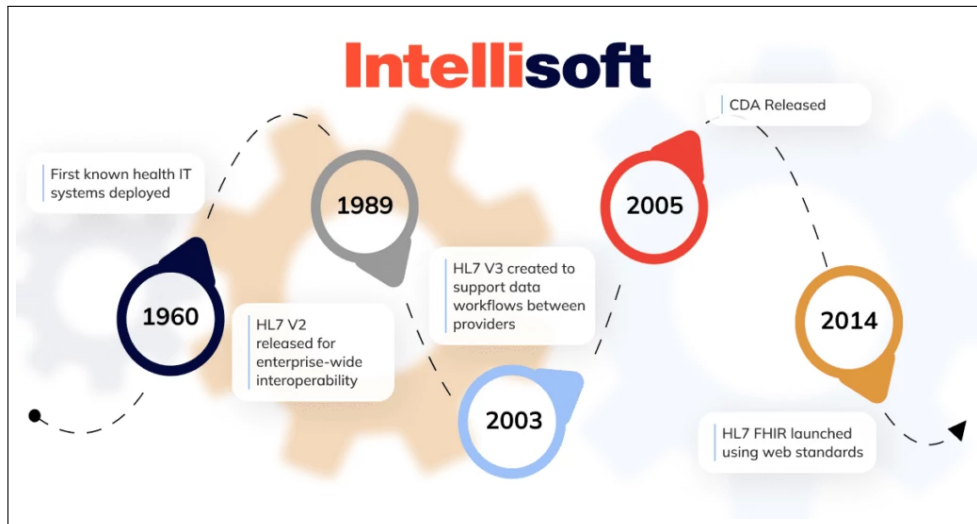


Figure 1.1: Evolution of HL7 Standards from Messaging to RESTful Resources.

1.3 Fast Healthcare Interoperability Resources (FHIR)

In response to the complexity of HL7 v3 and the limitations of v2, HL7 introduced **FHIR** (Fast Healthcare Interoperability Resources) in 2012. FHIR represents a paradigm shift from complex, custom healthcare protocols to modern web standards.

1.3.1 Core Architecture

Unlike its predecessors, FHIR is built on the RESTful API approach widely used in modern IT industries (e.g., by Google, Facebook, Twitter). It treats data elements as independent "Resources"—modular components like **Patient**, **Observation**, or **Medication**—that can be accessed and manipulated via standard HTTP methods (GET, POST, PUT, DELETE) [4].

1.3.2 Key Technical Advantages

- **Granularity via Resources:** FHIR allows systems to access specific data elements using unique URLs (e.g., `GET /Patient/123`), rather than exchanging entire heavy documents. This makes it ideal for mobile devices with limited bandwidth [4].
- **Modern Formats (JSON & XML):** While previous standards relied on complex XML or pipe-delimited text, FHIR natively supports JSON (JavaScript Object Notation), which is lightweight and directly parsable by web browsers and mobile apps [2].

- **The 80/20 Rule:** FHIR focuses on defining the 20% of requirements that satisfy 80% of common healthcare use cases. For the remaining complex or local requirements, it uses a built-in extension mechanism, ensuring the core standard remains simple and implementable [3].

1.3.3 Comparison of Standards

Table 1.1 highlights the fundamental differences between the major HL7 standards, illustrating why FHIR was chosen as the interoperability backbone for this project.

Table 1.1: Comparison of HL7 v2, v3, CDA, and FHIR Standards

Feature	HL7 v2	HL7 v3 / CDA	FHIR
Primary Paradigm	Event-Driven Messaging	Reference Model (RIM) / Documents	RESTful API & Resources
Data Format	Pipe-delimited text	Complex XML	JSON, XML, RDF
Transport	LLP / MLLP (TCP/IP)	SOAP / Web Services	HTTP / REST
Complexity	Moderate (Vague semantics)	High (Steep learning curve)	Low (Web-standard based)
Use Case	Hospital Backend (ADT, Orders)	Clinical Documents (Summaries)	Mobile, Web, Cloud, & Backend

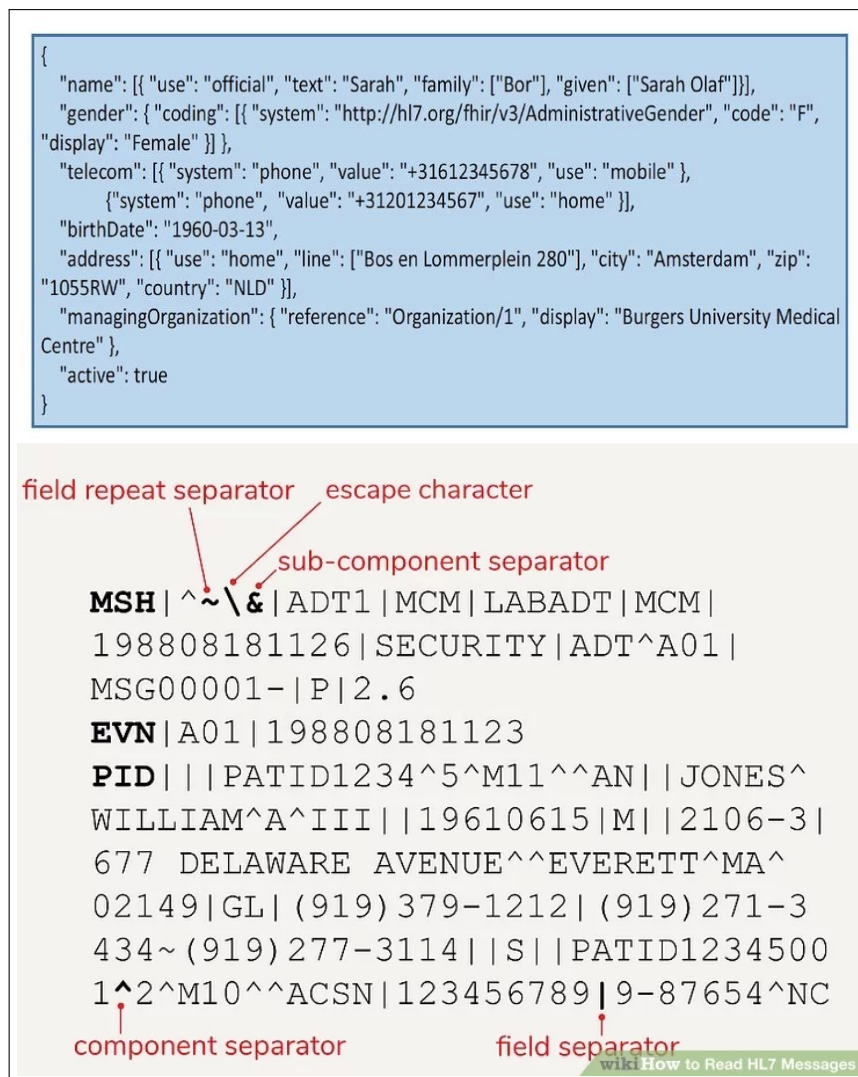


Figure 1.2: Visual Comparison of Data structure: HL7 v2 Message vs. FHIR JSON Resource.

Chapter 2

Literature Review

2.1 Authentication and Authorization Standards

2.1.1 OAuth 2.0 and OIDC

OAuth 2.0 [9] defines authorization grant flows: Authorization Code (web), Resource Owner Password (custom UI), Client Credentials (service-to-service). OpenID Connect (OIDC) [8] adds an identity layer with ID tokens and SSO. CFI-Care uses OAuth 2.0 Resource Owner Password flow with OIDC for token-based API access.

2.1.2 JSON Web Tokens (JWT)

JWTs [11] are signed tokens encoding claims (iss, aud, exp, roles, scopes). Stateless API authentication validates signatures without database queries. Token revocation requires server-side tracking or short expiration windows.

2.1.3 PKCE

PKCE [15] prevents authorization code interception attacks via code verifier/challenge. Recommended for all OAuth 2.0 flows [12].

2.2 Healthcare Security and Standards

2.2.1 FHIR and SMART on FHIR

FHIR [5] defines RESTful APIs for healthcare data exchange. SMART on FHIR [7] applies OAuth 2.0 to FHIR with scoped access (e.g., `patient/Observation.read`). The FHIR consent resource [6] models patient-controlled access with time-bound and actor-specific rules.

2.3 Token-Based Authentication Patterns

2.3.1 Session Management

HTTP-only cookies prevent JavaScript access [14]; SameSite blocks CSRF. token revocation uses redis-backed session tracking or OAuth 2.0 server revocation.

2.4 API Security

2.4.1 Rate Limiting

Rate limiting mitigates brute-force and enumeration attacks via Redis-backed counters [25].

2.4.2 Input Validation and XSS

Schema validation (Joi) enforces format/complexity rules. OWASP [22] recommends output encoding and CSP headers.

2.4.3 CSRF

CSRF [23] is mitigated with SameSite cookies and CSRF tokens.

2.5 Mobile Application Security

2.5.1 Secure Token Storage

Android Keystore [33] provides OS-level encryption and access control, unlike browser `localStorage`.

2.6 Audit Logging and Compliance

2.6.1 Security Event Logging

OWASP [27] specifies what to log and exclude audit logs enable forensics and compliance.

2.6.2 Threat Modeling

RFC 6819 [16] outlines OAuth 2.0 threats: token theft, interception, phishing, CSRF, replay.

2.7 Infrastructure and Deployment

2.7.1 API Gateway

nginx[24] terminates TLS, routes requests, enforces rate limits, and sets security headers.

Chapter 3

Proposed Design Architecture

3.1 System Architecture

The CFI-Care system is built upon a robust three-tier architecture designed to facilitate secure and interoperable healthcare data management. The system integrates a modern frontend, a logic-heavy middleware layer, and a standards-compliant backend to ensure data consistency and security. The architecture adheres to the FHIR (Fast Healthcare Interoperability Resources) standard for all medical data exchange and utilizes OAuth 2.0 via Keycloak for identity management.

3.1.1 High-Level Architecture

The application operates through a strict separation of concerns. The Presentation Layer is an Angular-based Single Page Application (SPA) that serves as the user interface. It does not communicate directly with the data stores. Instead, all client requests are intercepted by an Nginx Reverse Proxy, which handles SSL/TLS termination and routes traffic to the appropriate internal services.

The core of the backend processing is handled by the Node.js Application Server. This server acts as the primary API gateway, implementing business logic, enforcing security policies, and managing user sessions. It communicates with the HAPI FHIR Server, a specialized Java-based component responsible for persisting clinical data in compliance with the FHIR R5 standard. Data storage is consolidated in PostgreSQL databases, while high-speed data access and session management are handled by Redis instances.

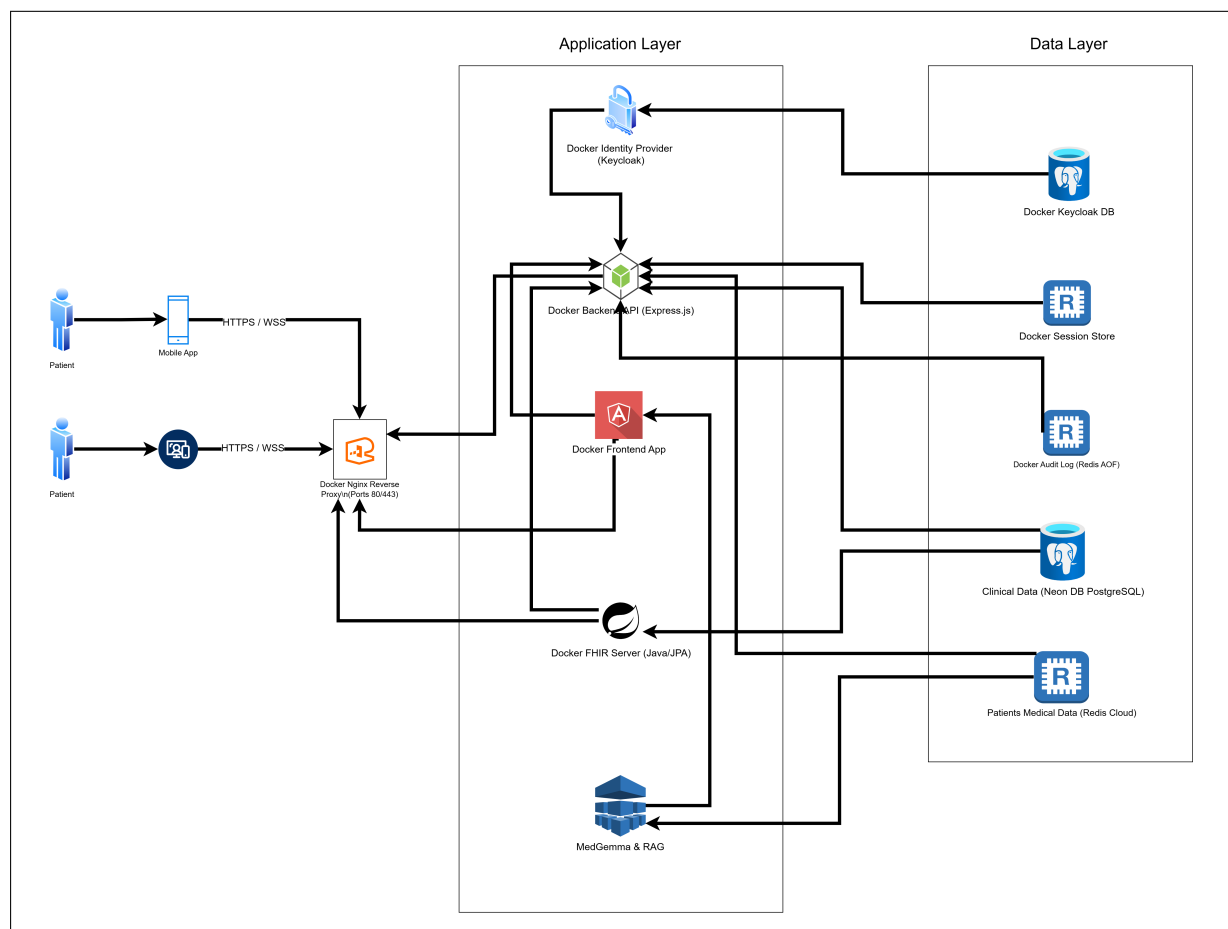


Figure 3.1: High-Level Container Architecture showing the interaction between the Nginx proxy, application services, and data persistence layers.

3.1.2 Node.js Application Server

The Node.js server, built with the Express.js framework, serves as the middleware layer that bridges the gap between the user interface and the standardized medical records. It is designed with a modular layered architecture to ensure scalability and maintainability.

Middleware and Security

Upon receiving a request, the server passes it through a comprehensive middleware stack. Security headers are applied using Helmet to prevent common web vulnerabilities. Cross-Origin Resource Sharing (CORS) is configured to restrict access to authorized domains. Crucially, the server implements rate limiting to protect API endpoints from abuse and utilizes a Redis-backed session store to manage user authentication states efficiently.

Routing and Services

The application is divided into specific route modules corresponding to healthcare domains. Dedicated endpoints manage Patients, Practitioners, Encounters, and Episodes of Care. A specialized "History Graph" module handles the retrieval and processing of graph visualization data.

Beneath the routing layer lies the service layer, which contains the core business logic. These services act as proxies to the FHIR server, transforming raw FHIR JSON into formats optimized for the frontend, such as the D3.js visualizations. They also handle document processing tasks, such as converting base64 strings to PDF files for binary storage.

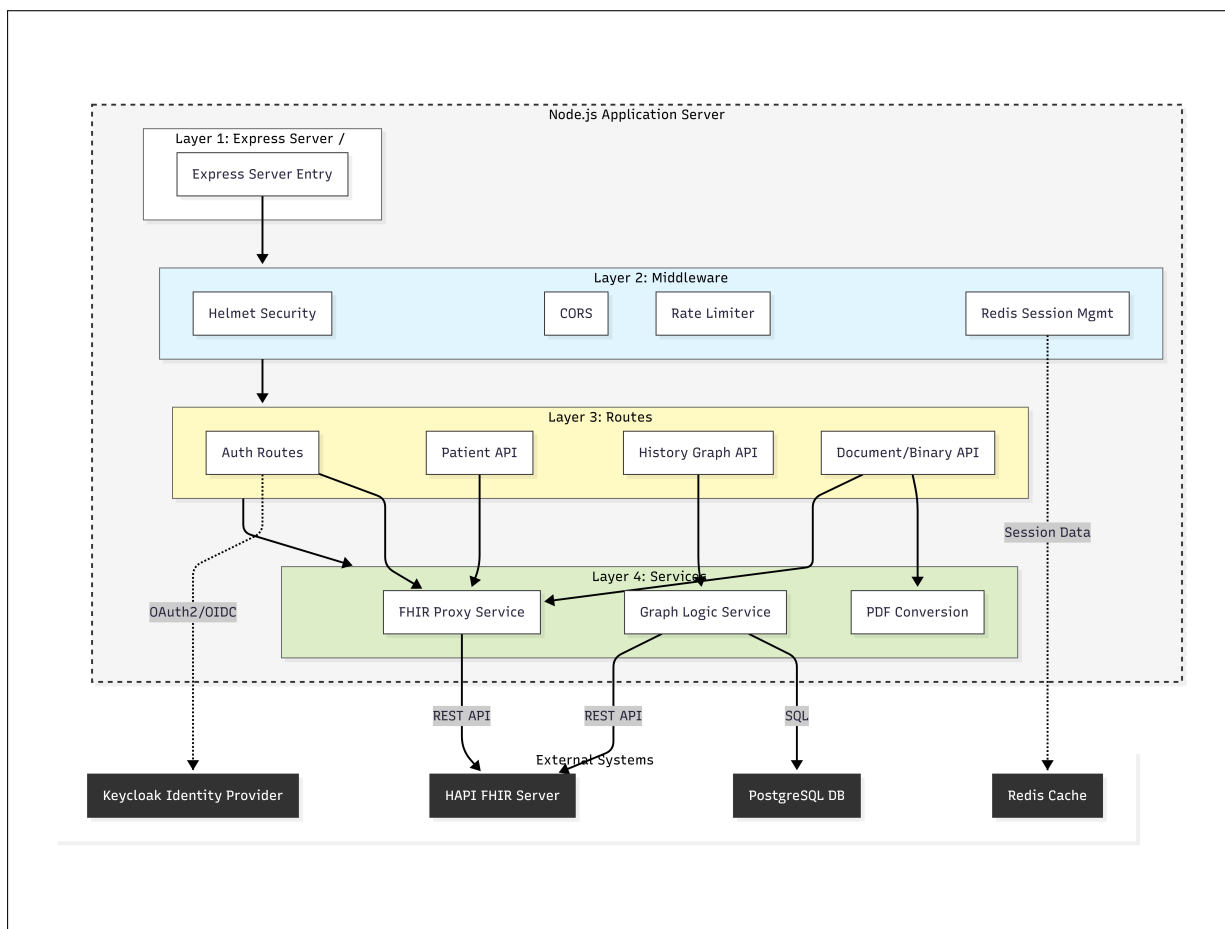


Figure 3.2: Internal layered architecture of the Node.js Application Server, detailing the middleware stack and service distribution.

3.1.3 Data Persistence and Schema

The system utilizes a polyglot persistence strategy, employing different database technologies for specific use cases to maximize performance.

Relational Data

The primary storage engine is PostgreSQL. It is divided into two logical segments. The first segment supports the HAPI FHIR server, storing all standard clinical resources (like Patients and Observations) in a highly structured format managed by Hibernate. The second segment supports the Keycloak identity provider, storing user credentials and realm configurations.

Custom Graph Schema

To support the unique "Medical History Graph" feature, a custom schema was designed alongside the standard FHIR tables. This schema consists of **encounter_nodes** and **node_relations**. These tables allow the system to map standard FHIR Encounters into a Directed Acyclic Graph (DAG), enabling the visualization of a patient's journey through time with causal links between medical events.

Caching and Auditing

Redis is utilized for ephemeral data storage. One instance is dedicated to storing user sessions, ensuring fast authentication checks. A second Redis instance operates in Append-Only File (AOF) mode to store audit logs, providing a persistent and high-speed trail of system activities.

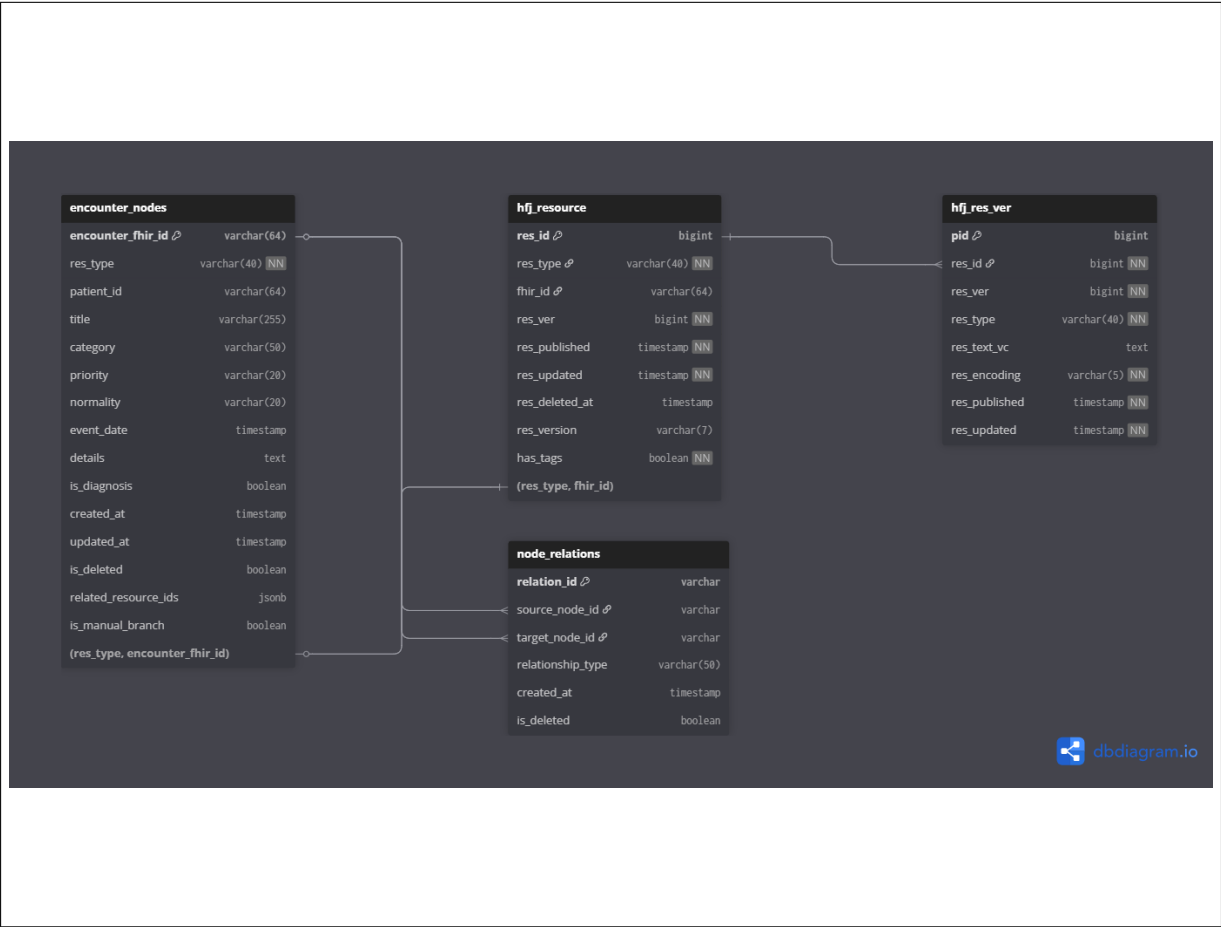


Figure 3.3: Entity-Relationship Diagram (ERD) illustrating the integration of custom graph tables with the standard FHIR resource table.

3.1.4 Request/Response Flow and Data Transformation Pipeline

Understanding how requests traverse the CFI-Care system is essential for comprehending the architecture’s design decisions. A typical request from the frontend follows a well-defined path through multiple layers, each contributing specific functionality: authentication verification, input validation, business logic execution, data transformation, and response formatting.

Request Ingress and Authentication

A request originates from the Angular frontend as an HTTP request, typically including a Bearer token in the Authorization header. The request first reaches the Nginx reverse proxy, which acts as the external-facing gateway. Nginx terminates the TLS/SSL connection, decrypts the HTTPS payload, and forwards the unencrypted request to the Node.js server over the private Docker network. Before the request reaches application

logic, it passes through the Helmet middleware, which applies security headers to prevent common web vulnerabilities such as XSS (Cross-Site Scripting), CSRF (Cross-Site Request Forgery), and clickjacking. The CORS middleware then validates that the request originates from an authorized frontend domain; requests from unauthorized origins are rejected immediately.

The next critical middleware validates the JWT token embedded in the Authorization header. The Node.js server maintains a cached set of public keys (JWKS) from Keycloak, updated periodically to handle key rotations. The token is cryptographically verified against these keys. If verification succeeds, the token claims (user ID, roles, permissions) are extracted and attached to the request context. If verification fails—due to an invalid signature, expired token, or missing token—the middleware returns a 401 Unauthorized response, and the request is rejected before reaching downstream services.

Concrete Example: Patient Data Retrieval

Consider a clinician’s request to retrieve a patient’s full medical history. The frontend issues a GET request to `/api/patients/:patientId`. After passing authentication and security middleware, the request reaches the routing layer, which dispatches it to the `PatientService` controller. The controller immediately implements input validation: the `patientId` parameter is checked to ensure it conforms to expected format (numeric ID or UUID, depending on the system design), and the authenticated user’s roles are verified to confirm they have permission to access that patient’s data (enforcing HIPAA privacy principles).

Before querying the database, the controller checks the Tier 1 cache (managed by `cacheHelper`). The middleware generates a deterministic cache key from the request URL: `cache:patients:patientId:{id}`. If a valid cache entry exists, the cached patient data is immediately returned with a 200 OK response, bypassing all downstream processing. This cache hit path typically completes in 20-50 milliseconds.

If a cache miss occurs, the request proceeds to the `PatientService` layer. The service constructs a FHIR query and forwards it to the HAPI FHIR server via an HTTP call: `GET /fhir/Patient/{patientId}`. The FHIR server retrieves the patient resource from PostgreSQL, performs any necessary transformations or computations required by the FHIR R5 standard, and returns the response in FHIR JSON format.

The `PatientService` receives the FHIR response and performs transformation operations: extracting relevant fields, formatting dates to match frontend expectations, computing derived values (e.g., age from birthdate), and sanitizing sensitive information if necessary. The transformed data is then stored in the Redis cache with a 1-hour TTL for future requests. Finally, the response is serialized to JSON and returned to the frontend with a 200 OK status code and appropriate cache headers to guide browser-side caching.

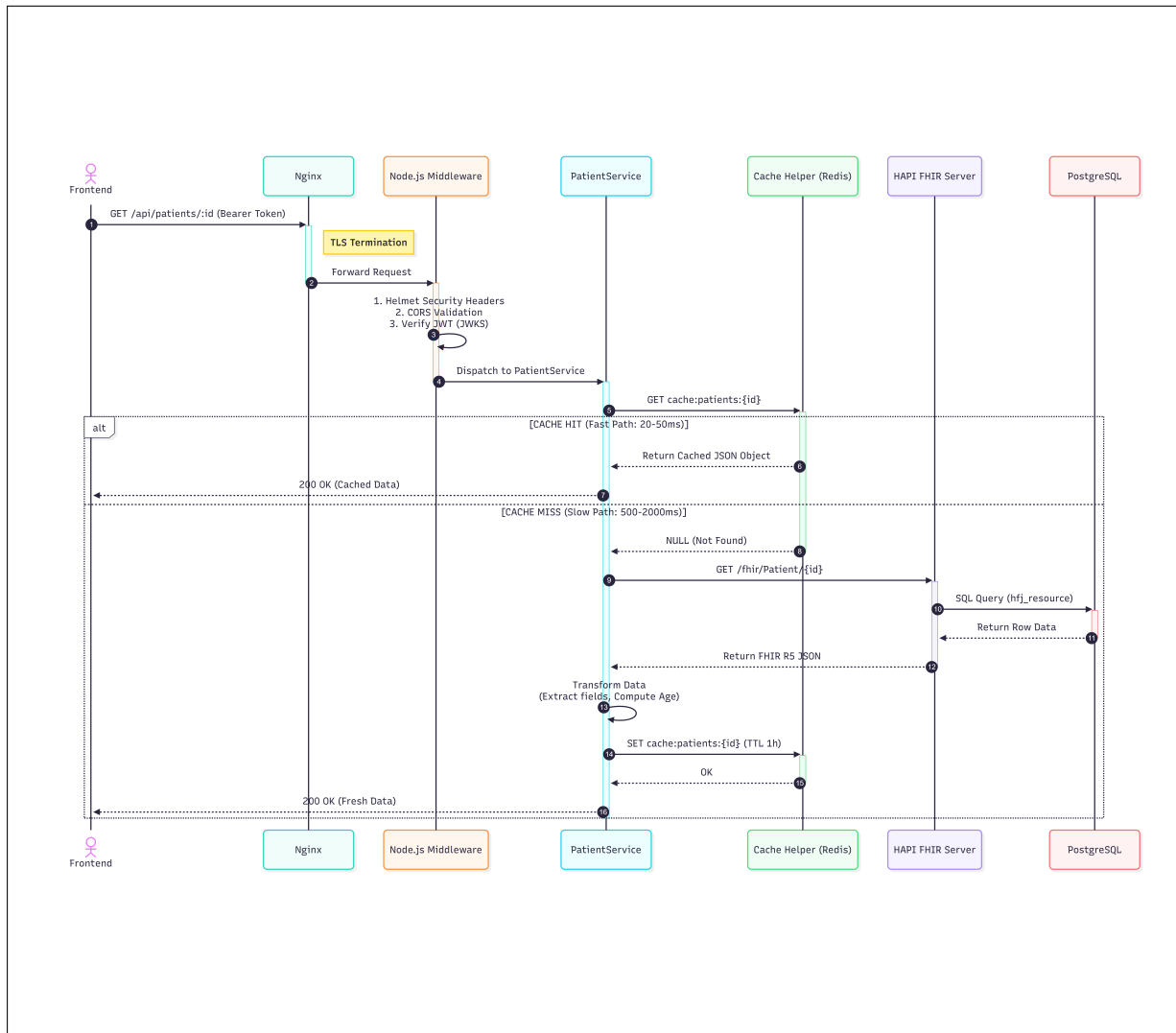


Figure 3.4: Request/Response flow for patient data retrieval, showing cache hit and miss scenarios with complete middleware pipeline.

Concrete Example: Encounter Creation and Graph Update

The encounter creation flow demonstrates more complex interactions across multiple system layers. When a clinician records a new consultation, the frontend issues a POST request to `/api/encounters` with a JSON payload containing encounter details (patient ID, encounter type, date, notes, etc.).

The request undergoes the same initial security and authentication pipeline as before. Upon reaching the `EncounterService` controller, the request enters the input validation phase. The encounter data is validated against a schema ensuring that all required fields are present and correctly formatted. The encounter date is verified to be a valid date and logically consistent (e.g., encounter date cannot be in the future). The patient ID is validated to ensure the patient exists in the system.

Next, the `EncounterService` constructs a FHIR Encounter resource conforming to the FHIR R5 standard and submits a POST request to the HAPI FHIR server: `POST /fhir/Encounter`. The FHIR server validates the resource, generates a unique FHIR resource ID, persists the resource to PostgreSQL, and returns the created resource with its new ID.

The encounter creation triggers a cascade of downstream operations. The `EncounterService` receives the FHIR response and extracts the newly created encounter's ID. It then invokes the `historyGraphService`, passing the new encounter data. The `historyGraphService` performs a temporal scan of existing nodes for the patient, identifies potential parent nodes based on clinical rules and temporal windows, and creates appropriate edges in the `node_relations` table. This graph construction may take several hundred milliseconds to several seconds depending on the patient's history size.

Concurrently, multiple cache entries are invalidated. The patient-specific Tier 2 graph cache is cleared immediately, ensuring that the next graph visualization request triggers a fresh reconstruction. The Tier 1 cache entry for the `/api/patients/{patientId}` endpoint is also invalidated, forcing a fresh FHIR server query for updated patient data.

Finally, the `EncounterService` returns the newly created encounter resource to the frontend with a 201 Created status code. The response includes the encounter's FHIR ID, allowing the frontend to reference this specific encounter in subsequent requests.

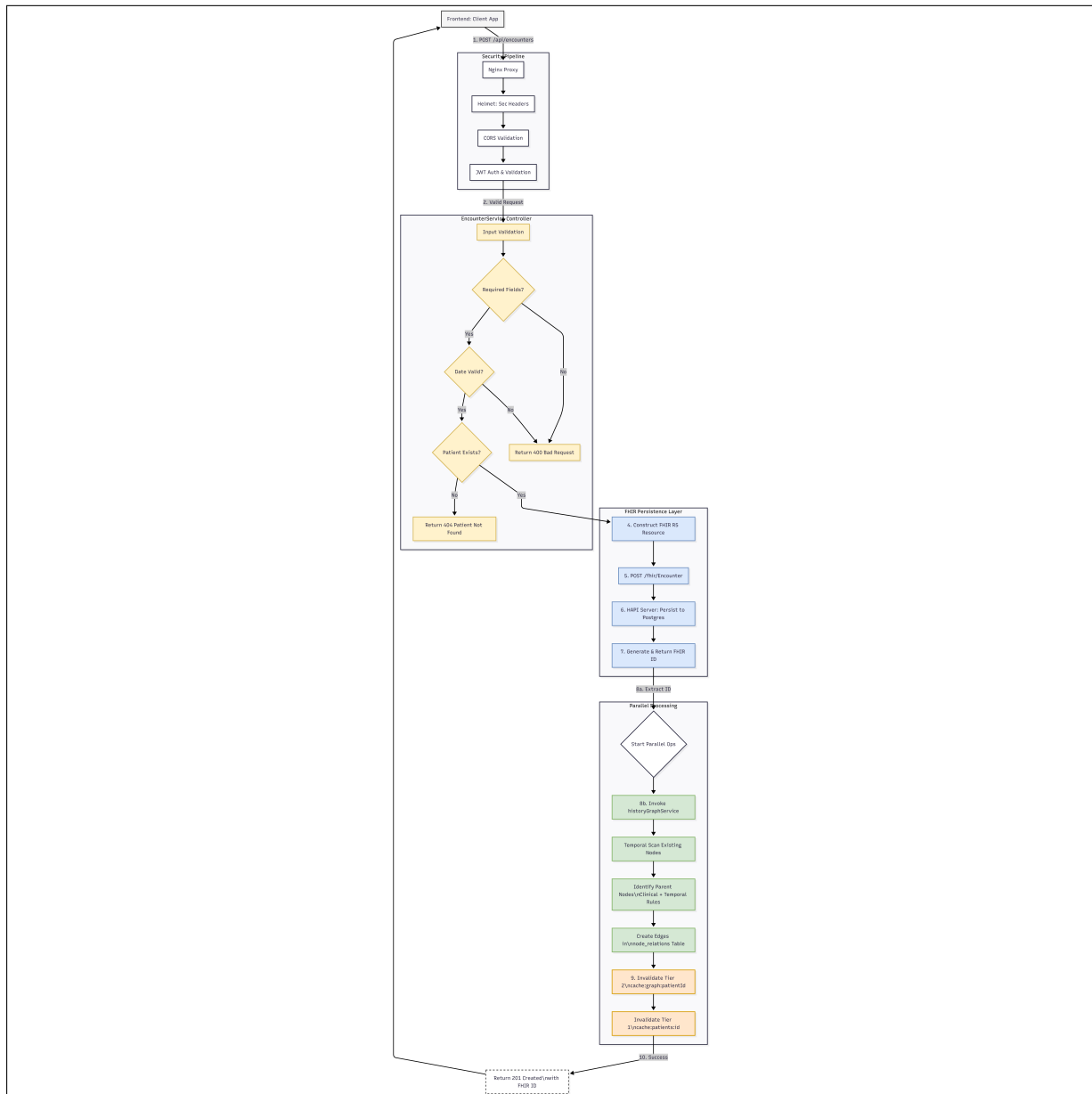


Figure 3.5: Complete encounter creation workflow showing FHIR resource persistence, graph construction, and cache invalidation cascade.

Validation Points and Error Conditions

Throughout this flow, validation occurs at multiple critical junctures. Input validation at the controller layer ensures that user-supplied data conforms to expected types and ranges. Business logic validation in the service layer verifies that operations are consistent with clinical rules (e.g., an encounter date cannot precede a patient’s birth date). FHIR resource validation at the HAPI FHIR server ensures that resources conform to the FHIR R5 specification, preventing invalid data from being persisted.

Error conditions at any stage result in appropriate HTTP status codes and error messages: 400 Bad Request for input validation failures, 403 Forbidden for authorization violations, 404 Not Found for missing resources, 409 Conflict for data consistency violations, and 500 Internal Server Error for unexpected server failures. Each error response includes a structured JSON object with a unique error code, human-readable message, and optionally, detailed information about the nature of the failure, enabling clinicians and developers to understand and address issues.

3.1.5 Error Handling and Fault Tolerance

The CFI-Care architecture recognizes that healthcare systems cannot tolerate downtime or data loss. Error handling and fault tolerance are designed into every layer to ensure reliable operation and graceful degradation under failure conditions.

Layered Error Handling Strategy

Errors propagate through the CFI-Care system in a controlled, layered manner. At the lowest layer, database operations (PostgreSQL queries, Redis operations) can fail due to connection timeouts, query errors, or resource unavailability. The Node.js middleware layer implements error handlers that catch these exceptions, log them for diagnostics, and transform them into appropriate HTTP error responses that safely communicate the failure to clients without exposing internal implementation details (such as database error messages or stack traces).

The service layer implements domain-specific error handling. When a FHIR server call fails, the service layer attempts to determine whether the failure is transient (temporary network issue) or persistent (FHIR server down, resource not found). For transient failures, the service implements exponential backoff retry logic: the first retry occurs after 100 milliseconds, the second after 200 milliseconds, and subsequent retries double the wait time, capped at a maximum of 30 seconds. This approach allows temporary outages to resolve while avoiding overwhelming a recovering server with immediate retry attempts. For persistent failures, errors are returned to the client immediately rather than consuming retry attempts.

The controller layer handles errors from services and formats them appropriately for the client. A service that cannot retrieve a patient record returns an error code; the controller translates this into a 404 Not Found HTTP response with descriptive messaging.

Fallback Mechanisms and Graceful Degradation

When the FHIR server becomes temporarily unavailable, the CFI-Care system implements fallback strategies to maintain partial functionality. The caching layer becomes

the primary data source: clinicians can still access patient records that were recently viewed, as these records remain in the Redis cache. While cached data may not reflect the absolute latest updates, it permits continued operation during brief FHIR server outages.

For the Patient History Graph, if the graph reconstruction fails due to FHIR server unavailability, the system returns a cached version of the graph if one exists, even if it is slightly stale. This allows clinicians to view previously computed graphs rather than receiving a complete failure. A notification is displayed to indicate that the graph may not reflect recent changes.

For new operations that require FHIR server access (creating encounters, adding diagnoses), if the FHIR server is unavailable, the system cannot proceed and returns a 503 Service Unavailable response, informing the clinician that the action cannot be completed at this moment. Rather than accepting incomplete or invalid data, the system fails safely, requiring the user to retry when the service recovers.

Resilience for Cache Operations

Redis provides the caching infrastructure for both session management and data caching. If Redis becomes unavailable, the system implements fallback strategies. For session caching, a secondary in-memory session store provides a fallback mechanism, allowing authentication to continue for users with active sessions, though new sessions cannot be created. For data caching, cache misses gracefully trigger direct queries to the FHIR server, bypassing the cache entirely but maintaining functionality.

Both Redis instances (session store and audit log store) are configured with persistence mechanisms. The session Redis instance uses RDB snapshots to periodically save state to disk, enabling recovery of active sessions if the instance restarts. The audit log Redis instance operates in AOF (Append-Only File) mode, ensuring every write is persisted to disk before acknowledging the write, guaranteeing that audit logs are never lost even if the Redis instance crashes.

Logging and Observability for Error Diagnosis

All errors are logged with structured logging that includes timestamp, error level (ERROR, WARN, INFO), service component generating the error, error code and message, request context (user ID, patient ID, operation being performed), and stack trace for unexpected exceptions. This structured logging enables rapid diagnosis of issues: operators can search logs by error code to identify all instances of a particular failure, by user ID to understand a user's experience during an outage, or by component to focus on specific services.

Critical errors are propagated to alerting systems, enabling operators to be notified of failures in real-time. For instance, if the FHIR server becomes unavailable, an alert is triggered within seconds. If error rates exceed thresholds, alerts notify operators that the system is degrading. This proactive monitoring enables rapid response to emerging issues before they impact clinicians' ability to deliver care.

3.1.6 Security and Infrastructure Layer

The infrastructure is secured through a centralized Identity and Access Management (IAM) system using Keycloak. Keycloak handles all OAuth 2.0 and OpenID Connect flows, issuing JSON Web Tokens (JWT) that the Node.js backend validates against a public key set (JWKS).

All components are containerized using Docker and orchestrated via Docker Compose. The environment is isolated within a private bridge network, with Nginx acting as the sole entry point. Nginx enforces SSL/TLS encryption using locally generated certificates, ensuring that all data in transit is encrypted. Containers are configured with read-only file system mounts and strict privilege limitations to minimize the security attack surface.

3.1.7 HAPI FHIR Server Implementation

The core component responsible for standardizing healthcare data within the CFI-Care system is the FHIR Server. This server is implemented using the HAPI FHIR JPA Server Starter framework. It is built upon the Java Spring Boot ecosystem and provides a fully compliant implementation of the FHIR Release 5 (R5) standard. This choice ensures that all clinical data, regardless of its source, adheres to international interoperability protocols and persists reliably within the database.

To tailor the server for the specific needs of this project, several important configuration changes were applied to the default setup. To maintain a lightweight and efficient runtime, advanced features that were not immediately required were explicitly disabled. This includes the Clinical Reasoning module and the CDS Hooks service. Similarly, bulk export and import operations were deactivated to prevent unnecessary resource consumption. Conversely, the OpenAPI documentation endpoints were enabled. This configuration allows developers to inspect the API structure and test endpoints directly through a web interface.

The persistence layer is powered by a PostgreSQL database connected via the Hibernate JPA engine. Specific configurations were applied to the Hibernate settings to optimize performance. The system uses the dedicated `HapiFhirPostgresDialect` to ensure efficient SQL generation. Additionally, the database schema management is configured to automatically update the table structures upon server startup, ensuring that the database remains synchronized with the code.

The server is responsible for managing a wide array of clinical resources necessary for the application. These include foundational entities such as Patient and Practitioner, as well as clinical events like Encounters, Procedures, and Observations. It also handles complex data types, including MedicationRequests for prescriptions and Binary resources for storing documents like PDF files.

For deployment, the server utilizes a secure multi-stage Docker build process. The first stage uses Maven to compile the application code and generate the necessary artifacts. The final runtime image is built upon a "distroless" Java 17 base image. This approach significantly reduces the final container size and improves security by removing unnecessary operating system tools and shells from the production environment.

3.2 API Design and Endpoints

The communication between the frontend client and the backend server is established through a structured RESTful API. This design ensures that the system remains stateless and scalable, utilizing standard HTTP methods to perform operations on resources. The Node.js application server acts as the centralized gateway, exposing a unified set of endpoints that handle both standard clinical data and custom graph logic.

3.2.1 RESTful Structure and Formats

All API interactions strictly adhere to the Javascript Object Notation (JSON) format for both request bodies and response payloads. The system utilizes standard HTTP verbs to define the nature of the operation. GET requests are used exclusively for retrieving data without side effects, while POST requests handle the creation of new resources. PUT methods are employed for updating existing records, and DELETE methods remove specific resources when permitted.

Responses from the server are standardized to ensure predictability for the client application. Successful operations return a 200 OK status code accompanied by the requested data object. In cases of resource creation, a 201 Created status is returned. Error handling is centralized, ensuring that any failure creates a consistent JSON error object containing a human-readable message and a specific error code, rather than exposing raw server stack traces.

3.2.2 FHIR-Compliant Endpoints

A significant portion of the API is dedicated to proxying standard FHIR resources. Endpoints such as `/api/patients` and `/api/encounters` act as a validation and caching layer sitting in front of the HAPI FHIR server. When the frontend requests patient details, the Node.js server intercepts this call, validates the parameters, and then forwards the request to the underlying Java server. The response is strictly compliant with the FHIR R5 standard, ensuring that the data structure remains interoperable with other external healthcare systems.

3.2.3 Custom History Graph Endpoints

Beyond standard FHIR resources, the API exposes specialized endpoints designed to support the Patient History Graph visualization. The primary endpoint, `/api/historyGraph`, does not return a simple list of records. Instead, it aggregates data from multiple FHIR resources and transforms them into a graph structure containing nodes and relational edges. This allows the frontend to render the complex temporal relationships between medical events without needing to perform heavy data processing in the browser.

Method	Endpoint	Description
GET	/api/patients	Retrieve list of patients with pagination support
POST	/api/patients	Register a new patient with FHIR validation
GET	/api/encounters/:id	Get specific encounter details including clinical observations
GET	/api/historyGraph/:id	Get patient history graph nodes and causal relationships
POST	/auth/login	Authenticate user and obtain JWT token via Keycloak

Table 3.1: Key REST API Endpoints provided by the Node.js Backend.

3.3 Patient History Graph Implementation

A core distinguishing feature of the CFI-Care backend is the Patient History Graph, which visualizes a patient’s medical journey as a Directed Acyclic Graph (DAG). Unlike standard FHIR lists, which present data linearly, this graph models causal and temporal relationships between medical events. This representation provides clinicians with a sophisticated tool for understanding the evolution of a patient’s condition, particularly in complex cases involving multiple concurrent diagnoses or extended treatment histories.

3.3.1 Motivation: Beyond Linear Medical Records

Traditional Electronic Health Records (EHRs) typically present patient data as chronologically ordered events: a consultation on January 1st, a lab test on January 3rd, a prescription on January 5th, and so forth. While this linear representation is straightforward to implement and understand, it obscures the causal relationships that are essential to clinical reasoning. Consider a patient with Type 2 Diabetes presenting with hypertension and elevated cholesterol levels. In a linear record, these appear as separate events without explicit connection. However, a clinician recognizes that these conditions are causally related—elevated cholesterol and hypertension may be comorbidities stemming from the underlying metabolic dysfunction of diabetes.

The Patient History Graph addresses this limitation by explicitly modeling causality and temporal dependencies. Each medical event is represented as a node in the graph, and directed edges represent causal or temporal relationships. This graphical representation allows clinicians to trace the progression of a specific condition across multiple encounters

and interventions, identify temporal clusters of related events that may indicate disease progression or treatment response, visualize the impact of therapeutic interventions on subsequent clinical outcomes, and differentiate between independent medical episodes and related sequences of events. By making these relationships explicit, the graph transforms raw temporal sequences into clinically meaningful narratives that support more effective decision-making.

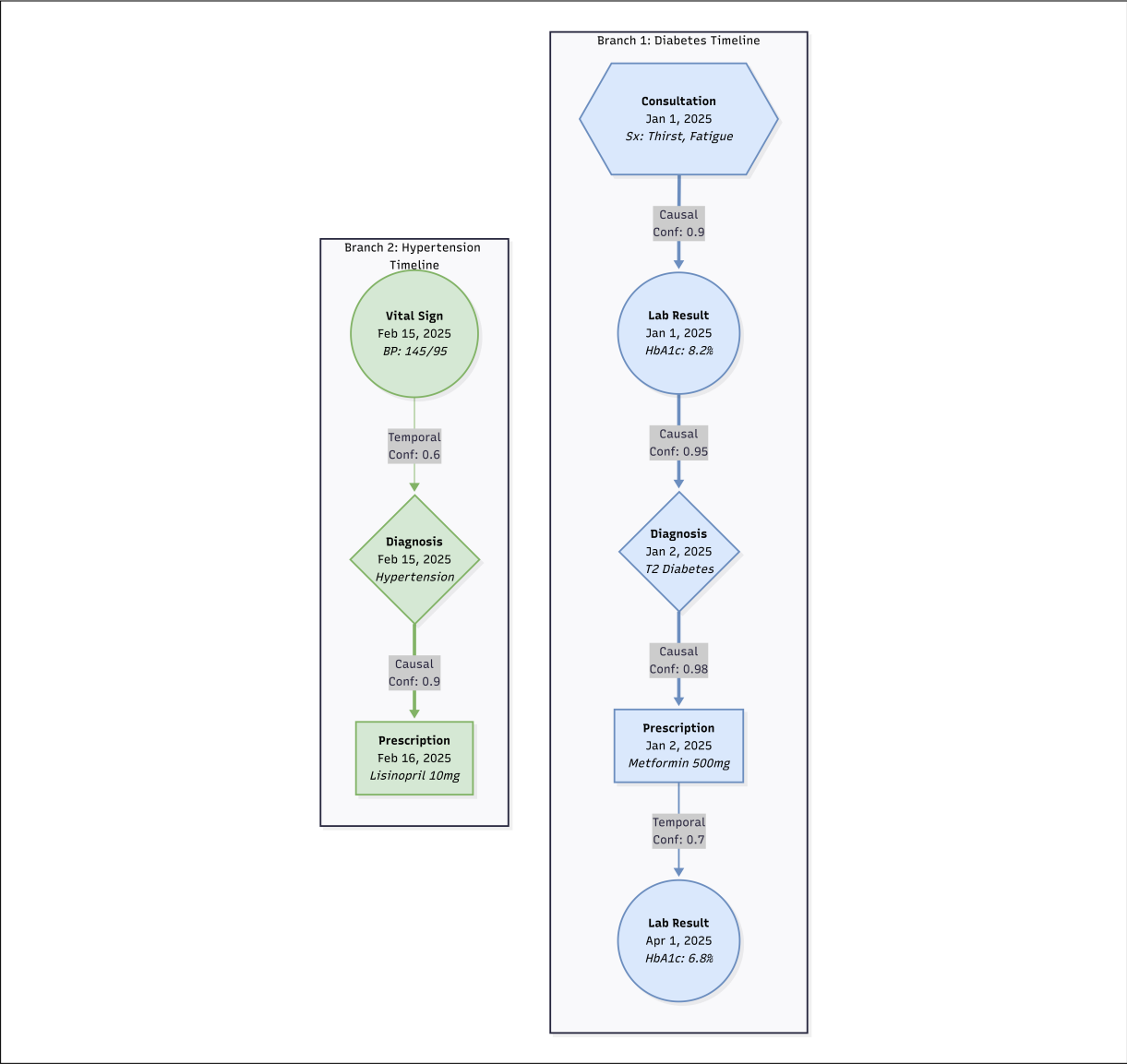


Figure 3.6: Example Patient History Graph showing a diabetes patient with concurrent hypertension, demonstrating temporal branching and multiple relationship types.

3.3.2 Graph Data Model

The Patient History Graph is built upon a relational foundation with two primary tables: `encounter_nodes` and `node_relations`.

Node Representation

Each node in the graph represents a distinct clinical event or observation. The system recognizes six primary node types: **Consultation** represents a clinical encounter between patient and clinician; **Diagnosis** denotes a confirmed medical condition recorded during or after a consultation; **Prescription** indicates a medication prescribed to address a specific condition; **LabResult** captures laboratory or diagnostic test results; **Vital** encompasses blood pressure, temperature, and other vital signs; and **Symptom** represents patient-reported subjective findings.

Each node stores rich metadata including its creation timestamp, an associated FHIR resource ID for traceability, its clinical category, and the patient to which it belongs. A fundamental design principle of the Patient History Graph is immutability: nodes, once created, cannot be modified or deleted. This architectural choice ensures that the graph preserves a complete and auditable record of the patient's medical journey, enabling clinicians to understand not just what happened, but also when records were created and by whom.

Edge Representation

Edges in the graph represent causal or temporal relationships. An edge from node *A* to node *B* indicates that event *A* preceded and potentially caused or informed event *B*. The system maintains an explicit `node_relations` table storing parent-child pairs, enabling efficient graph traversal for visualization and analysis.

3.3.3 Graph Construction Algorithm

The graph construction logic is encapsulated within the `historyGraphService`, a core backend service invoked whenever a new medical event is recorded. The algorithm operates in several stages:

Stage 1: Node Creation

When a new clinical event is received from the FHIR server (such as a new prescription, lab result, or consultation record), the system creates a corresponding node in the `encounter_nodes` database table. This node captures essential event information: the patient to which the event belongs, the clinical category of the event (Consultation,

Diagnosis, Prescription, etc.), the timestamp indicating when the event occurred, a reference ID linking back to the source FHIR resource for data provenance, and structured clinical details extracted from the FHIR resource including diagnosis codes, medication specifications, laboratory values, and other relevant clinical parameters.

Stage 2: Temporal Scanning and Parent Identification

After node creation, the algorithm performs a critical temporal backward scan of all existing nodes for the patient to identify potential parent nodes. This scan is bounded by three sets of clinical rules that determine what types of events can meaningfully be causally related. First, event type rules enforce domain-specific constraints: for instance, a Prescription node can only have a Consultation, Diagnosis, or another Prescription as a parent, while a Consultation cannot have a Prescription as a parent. These rules prevent semantically meaningless relationships from being created. Second, temporal window constraints ensure that relationships are only established between events within a clinically relevant time window. A prescription issued more than six months after a consultation is statistically unlikely to be causally related unless additional context suggests otherwise. Third, specificity matching ensures that the algorithm correctly associates events with their most clinically relevant predecessors. For example, a prescription for metformin (used in diabetes management) is linked to the most recent Diabetes diagnosis rather than to an unrelated hypertension diagnosis, even if both diagnoses exist in the patient's history.

The algorithm identifies the most recent "eligible" parent node based on these constraints. In cases where multiple candidates exist with similar temporal proximity, the system selects the most clinically specific match, prioritizing condition-specific diagnoses over generic symptoms or vice versa depending on the event context.

Stage 3: Edge Creation

Once a parent node is identified, a directed edge is created from parent to child in the `node_relations` table. The edge stores metadata including the relationship type (causal, temporal, or associative) and a confidence score indicating the algorithm's certainty in the relationship.

Algorithm Pseudocode

The following pseudocode formalizes the algorithm:

```
function constructGraphNode(newEvent, patientId):
    // Stage 1: Create node
    node = createNode(newEvent, patientId)
```

```

// Stage 2: Scan for parents
existingNodes = queryNodesByPatient(patientId)
candidateParents = []

for existingNode in existingNodes:
    if isValidRelationship(newEvent.type, existingNode.type):
        if isWithinTemporalWindow(newEvent, existingNode):
            if matchesClinicalContext(newEvent, existingNode):
                candidateParents.add(existingNode)

// Stage 3: Select and link parent
if candidateParents is not empty:
    parentNode = selectMostRelevantParent(candidateParents)
    createRelation(parentNode, node)
end if

// Invalidate cache
invalidateGraphCache(patientId)

return node
end function

```

3.3.4 Temporal Branching and Concurrent Episodes

Real-world patient histories are rarely linear. A patient may have multiple concurrent health issues being managed in parallel. For example, a patient may simultaneously receive treatment for diabetes, hypertension, and arthritis. In a traditional linear EHR, this complexity is flattened; all events appear chronologically without indication of which episode they belong to.

The CFI-Care graph model handles this through an explicit branching mechanism:

Head Node Concept

A "Head Node" is a node with no outgoing edges to other nodes in the current timestamp window. When a new clinical event arrives that does not fit within any existing causal chain (i.e., no valid parent is found), the system creates a new Head Node, effectively initiating a new branch in the history graph.

For example, consider a patient's history:

1. Consultation for chest pain (2025-01-01)

2. EKG test (2025-01-01)
3. Cardiology referral (2025-01-02)
4. New consultation for joint pain (2025-02-15) — **New Branch**
5. X-ray of knee (2025-02-15)
6. Rheumatology referral (2025-02-16)

The system recognizes that the joint pain consultation on 2025-02-15 cannot be causally linked to the earlier cardiology events (temporal gap exceeds threshold, clinical context is unrelated). Therefore, it creates a new Head Node for the rheumatology branch, allowing clinicians to visually separate the two episodes.

Visual Implications

From a visualization perspective, branching creates a multi-root forest structure (multiple separate trees within the graph). The frontend rendering engine positions these branches side-by-side or in hierarchical layout, enabling clinicians to track multiple concurrent conditions without visual clutter or confusion.

Clinical Advantages

Explicit branching provides significant clinical benefits that improve the utility of the Patient History Graph. Clinicians immediately recognize which events belong to which condition through visual separation, substantially reducing cognitive load compared to linearly ordered records. The system can provide condition-specific recommendations by analyzing the isolated branch rather than considering the entire patient history, enabling more targeted and relevant clinical decision support. Additionally, each branch can be summarized independently for specialist-to-specialist referrals, allowing specialists to focus on the specific problem domain without irrelevant context from other concurrent conditions.

3.3.5 Relationship Classification

Not all edges in the Patient History Graph carry the same semantic weight or clinical significance. The system classifies relationships into three distinct types to preserve this important distinction. Causal relationships represent situations where Node *A* directly caused or necessitated Node *B*. For example, a Diabetes Diagnosis directly necessitates a Metformin Prescription. These edges carry high confidence scores and strong clinical significance, indicating a clear cause-and-effect relationship. Temporal relationships occur when Node *A* preceded Node *B* within the same clinical episode, but causality is not

explicitly established. For instance, a Consultation followed by a Blood Pressure Reading taken during the same visit represents a temporal relationship rather than a causal one. Associative relationships capture scenarios where Node *A* and Node *B* are related through shared clinical context—such as both addressing the same underlying condition—but neither directly causes the other. For example, a High Cholesterol Lab Result and a Diabetes Diagnosis both present in the same patient might be associated through their shared metabolic dysfunction.

Each relationship in the graph stores a confidence score ranging from 0.0 to 1.0, generated by the construction algorithm based on how well the relationship satisfies the various constraint criteria. High-confidence relationships with scores exceeding 0.8 are displayed prominently in the visualization, while lower-confidence relationships are shown with reduced visual emphasis or as optional links that the clinician can explore if desired.

3.3.6 Handling Edge Cases

The Patient History Graph implementation must gracefully handle several challenging scenarios that arise in real-world clinical practice. Retroactive diagnosis occurs when a patient receives a diagnosis that applies to earlier symptoms after those symptoms have already been recorded. For example, a patient might experience chest pain on January 1st and only receive a diagnosis of coronary artery disease on March 1st. The algorithm detects this temporal mismatch and retroactively relinks the symptom node to the new diagnosis, maintaining causal clarity and preventing the false impression that the symptom was unexplained.

Conflicting information presents another challenge. When new FHIR data contradicts previously recorded information—such as a diagnosis being changed, retracted, or corrected—the system must handle this gracefully. Rather than deleting nodes (which would violate the immutability principle and destroy the audit trail), the system creates a new node representing the correction and links it appropriately to existing nodes. This approach preserves the complete historical record while accurately reflecting the current clinical understanding.

Circular references represent a potential structural problem. Although directed acyclic graphs (DAGs) cannot, by definition, contain cycles, the algorithm must validate that no accidental cycles are introduced during edge creation. This validation is enforced through topological sorting checks performed before persisting relationships to the database, preventing data consistency issues that could arise from cycles.

3.3.7 Query Patterns and Optimization

The frontend visualization layer requires efficient access to the graph structure through several common query patterns, each optimized for specific clinical use cases. Full Graph Retrieval fetches all nodes and edges for a patient, which is necessary during the initial

page load when clinicians first view a patient’s complete medical history. This operation is optimized through caching strategies discussed in Section 3.4. Ancestor Traversal answers questions such as ”What led to this prescription?” by fetching all ancestor nodes of a specific event. This pattern is implemented via recursive queries that are bounded by depth to prevent unbounded traversals. Branch Isolation allows clinicians to focus on specific medical episodes, such as ”Show only cardiology-related events,” by fetching all nodes within a specific branch. This operation uses topological partitioning to efficiently isolate branches without scanning the entire graph. Temporal Range Queries retrieve nodes within a specific date range, enabling clinicians to analyze disease progression over a specific time period. These queries leverage indexed timestamp columns to achieve $O(\log n)$ lookup time complexity, ensuring responsiveness even for patients with extensive histories.

3.4 Performance Optimization

To ensure low-latency responses for the frontend visualizations, the backend implements a specialized Two-Tier Caching Strategy using Redis. This hierarchical caching approach balances data freshness with response times, recognizing that different types of medical data have different update frequencies and computational costs.

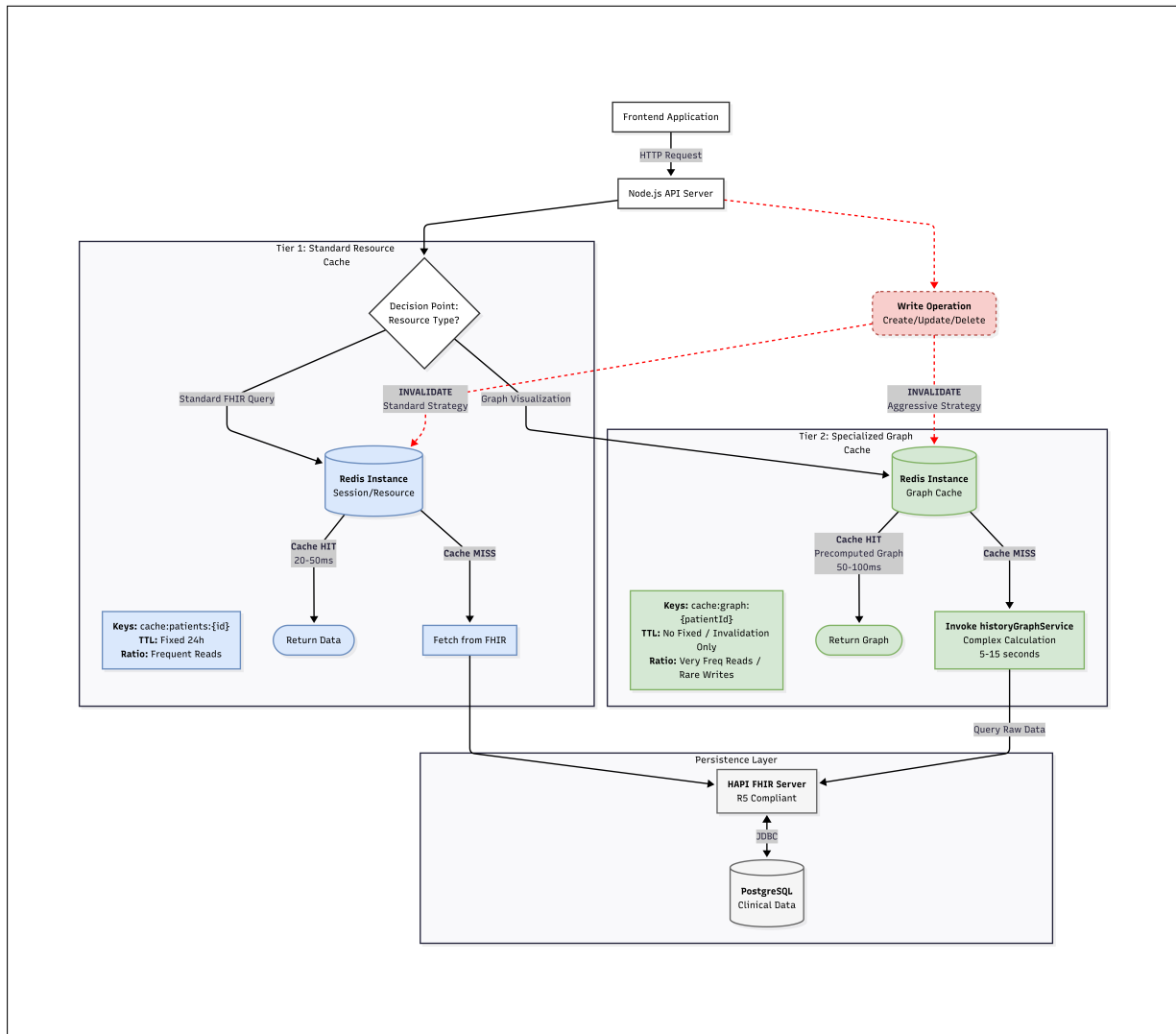


Figure 3.7: Two-Tier Caching Architecture showing distinct strategies for standard FHIR resources (Tier 1) and complex graph structures (Tier 2).

3.4.1 Tier 1: Standard Resource Cache

The first tier utilizes a generic `cacheHelper` middleware that intercepts HTTP requests for standard FHIR resources. This middleware operates at the request level, functioning as a transparent cache layer between the frontend client and the backend processing pipeline.

Mechanism and Interception

When an HTTP request arrives at the backend (such as a GET request to `/api/patients`), the `cacheHelper` middleware performs a sequence of operations to determine whether a

cached response can be served. The middleware first generates a deterministic cache key from the request URL and query parameters—for example, a request to `/api/patients?page=1&limit=20` generates the key `cache:patients:page:1:limit:20`. The middleware then queries the Redis cache for an entry matching this key. If a valid cache entry exists, meaning the entry has not expired, the cached response is immediately returned to the client, entirely bypassing the FHIR server, database query execution, and all downstream processing. This direct cache-to-client path reduces latency from potentially 500-2000ms (database query time) to sub-50ms (Redis in-memory retrieval). If no entry exists or the entry has expired, the request proceeds through the normal processing pipeline: the backend queries the FHIR server, processes the response, and returns it to the client. Before returning, the response is stored in Redis for future requests, repopulating the cache.

Time-To-Live (TTL) Management

Cached FHIR resources are assigned a default Time-To-Live (TTL) of 1 hour, representing a clinically acceptable window where cached data is considered sufficiently fresh for clinical use. This 1-hour window is chosen based on several practical considerations. From a clinical workflow perspective, most healthcare workflows operate on new fresh data every hour. A patient’s medication list, diagnosis history, and vital signs are statistically unlikely to change multiple times within a single hour in most clinical scenarios. From a system load perspective, a 1-hour TTL significantly reduces the query volume to the underlying FHIR server and database, minimizing computational load during peak usage hours when many clinicians are accessing patient data simultaneously. While the 1-hour window does introduce some degree of data staleness, this tradeoff is clinically acceptable for read-heavy operations on relatively stable data that changes infrequently.

However, the TTL is configurable on a per-resource-type basis to accommodate different data freshness requirements. Real-time vital signs or active medication adjustments might use a shorter TTL of one hour to ensure clinicians see recent changes, while historical diagnoses that rarely change might use a longer TTL of 12 hours to reduce computational overhead.

Cache Invalidation for Tier 1

Although Tier 1 uses a fixed TTL-based expiration, certain write operations trigger explicit cache invalidation to ensure data consistency. When a patient record is modified—such as contact information changes or new allergies being recorded—the corresponding cache entries for that patient are immediately removed, forcing a fresh fetch on the next request. Similarly, when a new encounter is recorded or an existing one is updated, the cache entries for `/api/encounters` are invalidated to reflect the changes. The system maintains a comprehensive mapping of dependencies between cache keys and FHIR resources. When a resource is modified, all dependent cache entries are invalidated simultaneously, preventing scenarios where multiple cache entries contain stale references to the same resource.

Practical Impact

The practical benefit of Tier 1 caching becomes apparent in typical clinic workflows where healthcare providers request the same patient’s record multiple times during a single day. Without caching, each request would trigger a database query taking 500-1000ms, and checking the same patient 5 times would incur 2500-5000ms of cumulative latency. With Tier 1 caching in place, the first request incurs the full latency of 500-1000ms, but subsequent requests within 24 hours are served from cache in approximately 20-50ms each. For five checks of the same patient, the total latency becomes 500-1000ms plus 80-200ms for the cached requests, totaling 580-1200ms. This represents a 75-80 percent reduction in latency, dramatically improving the responsiveness of the system and reducing clinician wait times during patient data retrieval.

3.4.2 Tier 2: Specialized Graph Cache

The second tier is specifically designed for the computationally intensive Patient History Graph. While Tier 1 caches simple resource retrieval, Tier 2 caches the results of complex graph construction and relationship mapping.

Computational Cost of Graph Construction

Constructing a Patient History Graph from raw FHIR resources is computationally expensive for several interconnected reasons. Data aggregation requires retrieving all FHIR resources for a patient, including consultations, diagnoses, prescriptions, lab results, vitals, and symptoms, potentially from multiple FHIR repositories. A patient with an extensive medical history might have hundreds of such resources, necessitating multiple server calls and database queries. Relationship inference constitutes the most computationally intensive phase. For each new node, the algorithm must scan all existing nodes for that patient, evaluate whether causal relationships should exist by checking temporal windows, clinical context compatibility, and event type rules, compute confidence scores for each potential relationship, and determine the most relevant parent. This represents an $O(n)$ operation where n is the number of existing nodes, and complex patients with 500+ nodes can require significant computational resources. Graph formatting transforms the raw graph structure into a visualization-ready format suitable for the frontend rendering library. This transformation includes computing optimal node positions in the visual layout, determining visual attributes such as color, size, and emphasis, serializing the entire structure to JSON, and applying any additional formatting for the specific frontend framework. For a patient with 500 nodes, these cumulative operations can collectively require 5-15 seconds of computational time—far too slow for the responsive interactive experience that clinicians expect.

The Graph Cache Manager: `toonNodesCacheHelper`

The `toonNodesCacheHelper` service manages caching specifically for the Patient History Graph. Unlike the generic Tier 1 cache which uses simple TTL expiration, the graph cache is patient-specific and extensively optimized for the unique characteristics of graph data. Each patient has a dedicated cache entry with the key `cache:graph:{patientId}`, containing their complete precomputed graph structure. The cache value stores a comprehensive JSON object containing all nodes with their associated metadata (type, timestamp, clinical details), all edges with their relationship types and confidence scores, and precomputed visual attributes including node positions and branch assignments. Unlike Tier 1 caching which relies on fixed TTL expiration, the graph cache does not use time-based expiration at all. Instead, it relies entirely on explicit invalidation to ensure that cached data always reflects the current patient history.

Aggressive Invalidation Strategy

The graph cache employs an aggressive invalidation approach that prioritizes data consistency over computational efficiency. Any write operation to a patient's medical history immediately invalidates their corresponding graph cache entry. This design reflects a fundamental tradeoff in the caching strategy: write operations are relatively rare compared to read operations in clinical workflows, while read operations dominate. A single patient might have their graph read hundreds of times per day across multiple clinicians viewing the same patient from different workstations or different clinical contexts, yet the patient's medical history is modified only a few times per day. Given this asymmetry, it is computationally more efficient to invalidate the cache upon writes (an immediate operation) than to maintain cache staleness during reads or to implement complex update-in-place strategies. The invalidation is triggered by several categories of events: recording a new clinical event such as a consultation, diagnosis, prescription, or lab result; updating or correcting an existing node; modifying relationships between nodes; or retracting or changing a diagnosis or medication. Any of these operations immediately removes the cached graph, forcing reconstruction on the next request.

Cache Reconstruction Workflow

When a graph cache miss occurs, either due to invalidation from a write operation or because the cache has never been populated for that patient, a well-defined reconstruction workflow is executed. The frontend or backend first requests the graph for the patient. The `toonNodesCacheHelper` detects the cache miss and invokes the `historyGraphService` to reconstruct the graph from scratch. The reconstruction process retrieves all FHIR resources for the patient, executes the complete graph construction algorithm including temporal scanning and parent identification, and computes visual attributes. Once complete, the entire graph structure is serialized to JSON and stored in Redis. The fully reconstructed cache is then returned to the requesting client. Subsequent requests within

the same session or from other clinicians viewing the same patient retrieve the cached graph in sub-100ms latency, providing responsive interactive performance.

Hit Rate and Performance Impact

The effectiveness of the graph cache in improving system performance depends heavily on the read-to-write ratio, which varies depending on the clinical workflow pattern. In read-heavy workflows, which represent the typical clinical use case, a clinician views a patient's graph multiple times during a consultation, compares it with previous snapshots to track disease progression, and discusses findings with colleagues or consulting specialists. The same graph may be read 10-20 times before any modification to the patient record occurs. In these scenarios, the graph cache achieves hit rates of 85-95 percent, resulting in dramatic performance improvements. A graph that would normally require 15-20 seconds of computational time to construct is served from cache in 50-100ms, a 100-200x latency reduction. In contrast, write-heavy workflows are rare but do occur, such as when a clinician is entering comprehensive historical data for a newly-registered patient, recording 20-30 events that generate new medical events in quick succession. Each new event triggers cache invalidation, causing multiple cache misses and requiring full reconstructions. In these scenarios, the cache hit rate drops to 20-30 percent. The aggressive invalidation strategy in this case sacrifices caching efficiency to ensure that data consistency is always maintained. In typical clinical workflows, the combination of read-heavy access patterns and Tier 2 caching provides a 100-200x latency improvement for graph visualization, translating to substantially more responsive clinical interfaces and reduced clinician wait times.

Coordination Between Tier 1 and Tier 2

The two caching tiers work in close coordination to maximize performance across different types of requests. When the frontend requests standard FHIR resources such as a patient list or individual patient demographic data, Tier 1 cache is checked first, providing rapid responses for frequently accessed basic information. When the frontend requests the complex Patient History Graph visualization, Tier 2 cache is consulted, serving the pre-computed graph structure with all relationships and visual attributes already prepared. Invalidation operations propagate across both tiers simultaneously. For example, recording a new prescription invalidates both the Tier 1 cache entry for `/api/prescriptions` (which would now be stale relative to the 24-hour TTL) and the Tier 2 cache for that patient's history graph (which must be reconstructed to include the new node and relationships). This coordinated invalidation ensures that regardless of which API endpoint a clinician accesses, the data reflects the most recent state of the patient's record.

Memory Management and Cache Eviction

Redis is configured with a maximum memory limit to prevent unbounded growth and to integrate into production server resource constraints. To manage memory efficiently,

the CFI-Care backend employs an LRU (Least Recently Used) eviction policy. When Redis approaches its configured maximum memory capacity, the system automatically evicts the least recently accessed cache entries to make space for new data. This dynamic approach to cache management creates a natural working set where the cache automatically retains entries for patients with active clinical workflows (frequently accessed by multiple clinicians) while entries for inactive patients are evicted and subsequently reconstructed on-demand if and when those patients are accessed again. This ensures that memory usage remains bounded and predictable while simultaneously maximizing cache hit rates for the active subset of patients. In practice, this means that high-volume clinical workflows benefit from maximum cache coverage, while less frequently accessed patients gracefully degrade to on-demand reconstruction without requiring administrator intervention or manual cache management.

3.5 Frontend

3.6 Mobile

Chapter 4

Security

4.1 Introduction

Healthcare information systems are prime targets for security breaches due to the commercial value of protected health information (PHI) . CFI-Care platform presents multi-layered challenges: securing web-based browser access, mobile device authentication, sensitive patient consent grants, and doctor-patient access workflows. Also maintaining audit trails is required and so is enabling session revocation.

Traditional monolithic security approaches are insufficient for this use case. Instead, we adopted a defense-in-depth strategy leveraging modern standards (OAuth 2.0/OIDC with JWT) and distributed validation across the API gateway (nginx), backend-for-frontend (Node.js/BFF) and FHIR server for final checks before database access.

4.2 Architecture & Design

The CFI-Care security architecture follows a defense-in-depth model with multiple validation layers. Figure 4.1 provides an overview of the security components and their interactions. Figures 4.2, 4.4, and 4.5 illustrate the key authentication and authorization flows across browser, mobile workflows. This section details the design and implementation principles.

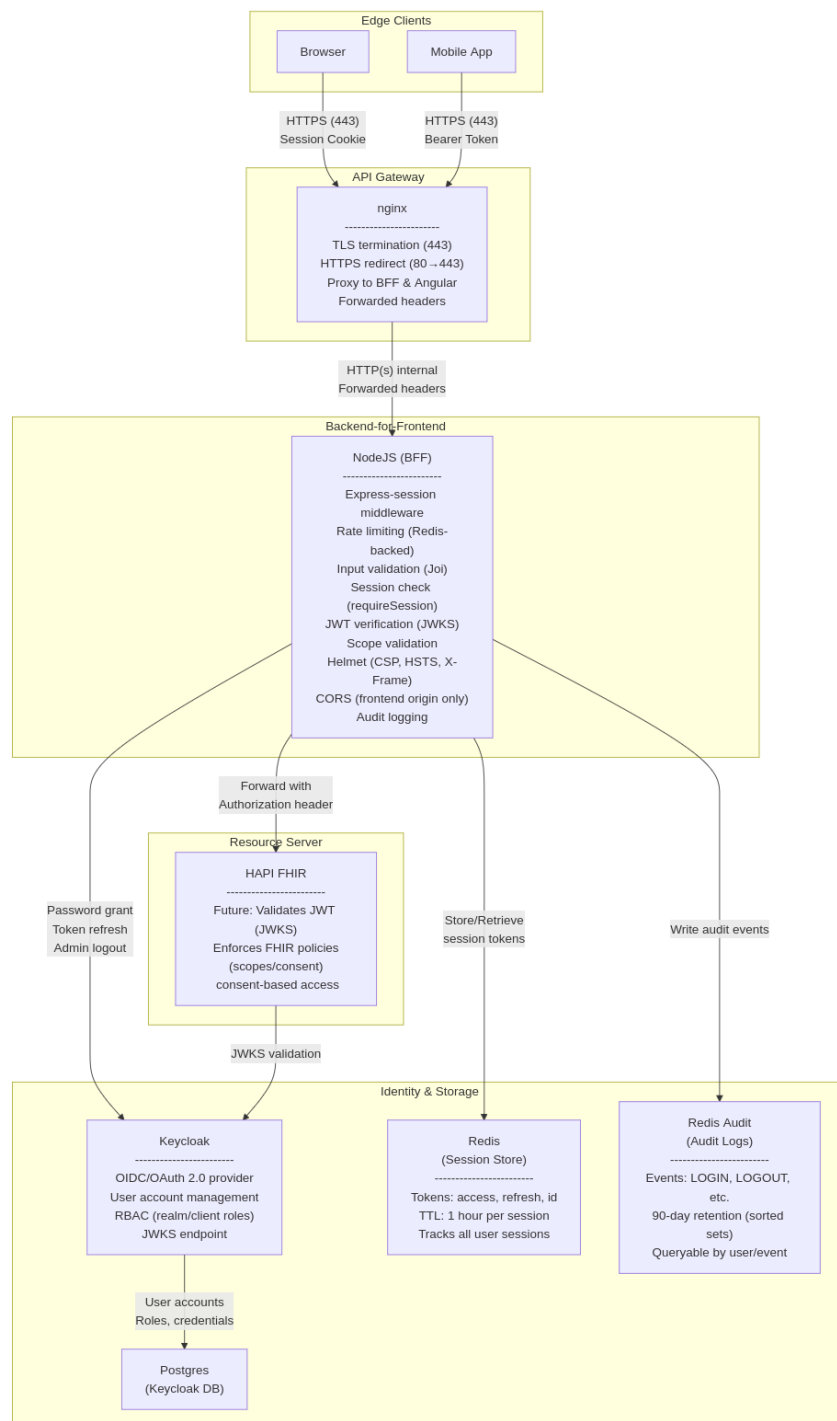


Figure 4.1: Security Architecture Components: Edge clients (Browser, Mobile), API Gateway (nginx), Backend-for-Frontend (Node.js), Identity & Storage (Keycloak, Redis, Postgres), and Resource Server (HAPI FHIR) with their security-focused interactions.

4.2.1 Identity & Access Management

Keycloak Realm & Clients

Keycloak is our chosen identity provider. A dedicated realm hosts a client for the web application (via the BFF) and a client for mobile usage. For the current browser flow, the BFF obtains tokens using the Resource Owner Password grant (password grant) and stores them server-side. Access, refresh, and ID tokens are issued as JWTs and validated downstream using JWKS.

Browser Flow

The browser authenticates against a custom login endpoint exposed by the BFF. On success, the BFF stores tokens in a Redis-backed session and returns a secure, HTTP-only cookie. All subsequent browser requests carry only the session cookie (no tokens in the browser).

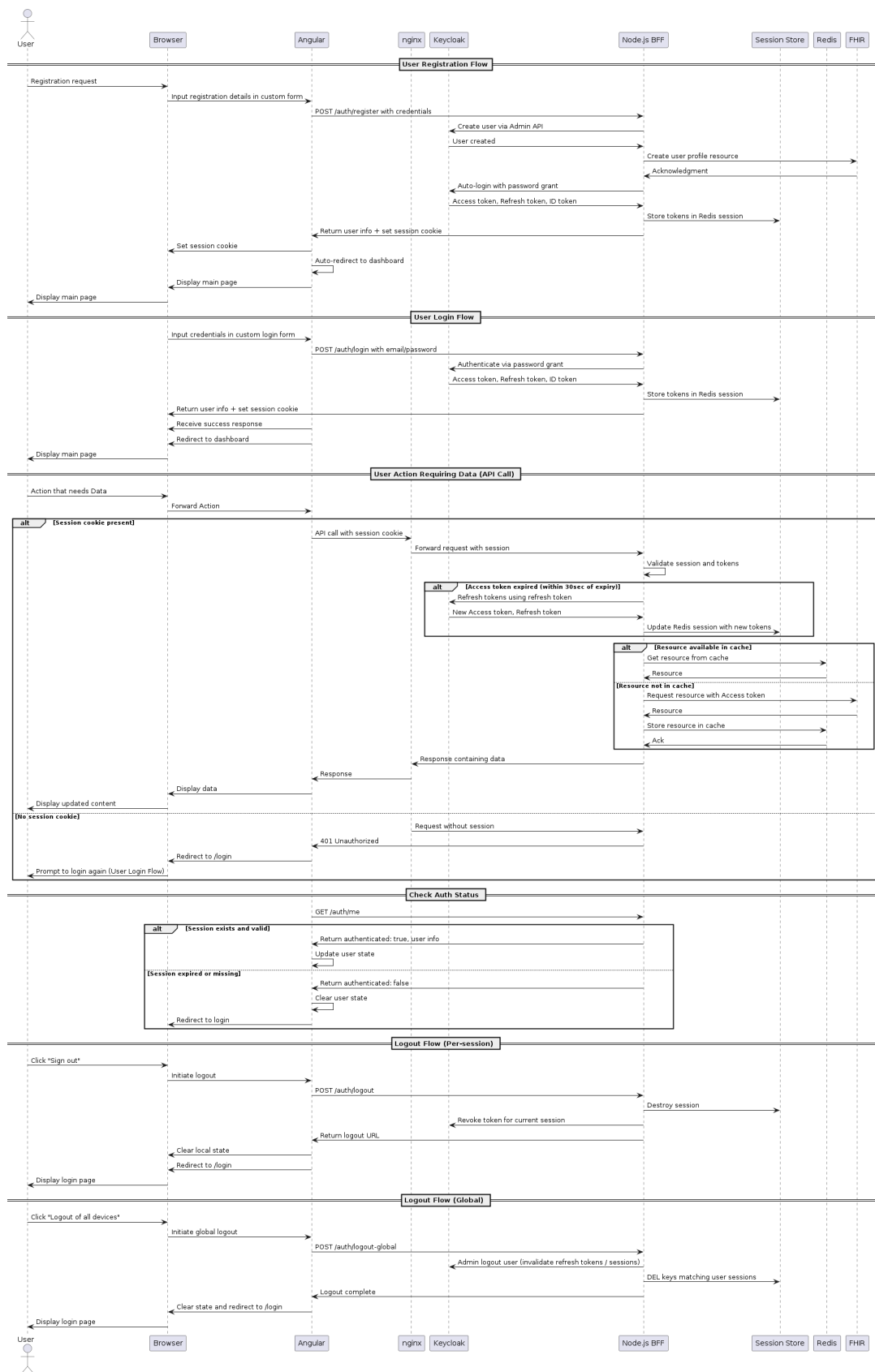


Figure 4.2: Browser Token Authentication Flow: User registration, login, and API request handling with session cookies.

Planned Browser Hardening (Email Verification) A future iteration will keep the custom Angular UI while hardening login with email verification and a MFA option. Tokens remain short-lived, stored in Redis-backed sessions for browsers, and refreshed transparently by the BFF. The planned flow is captured in Figure 4.3.

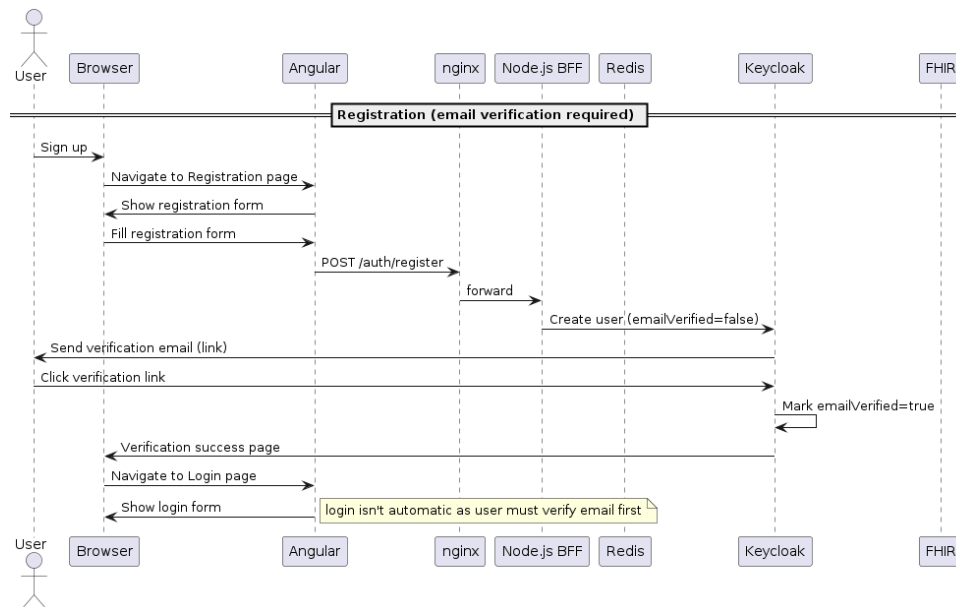


Figure 4.3: Planned Browser Flow (Future): Registration with email verification and BFF-mediated credential login, session cookie issuance, and server-side token refresh.

Mobile Flow

For mobile clients (implemented using Flutter), the flow differs from browsers. The planned implementation uses a BFF-mediated Authorization Code pattern with PKCE, and stateless access tokens. Tokens are stored only in platform-specific secure storage (Android Keystore) and sent as `Authorization: Bearer <token>` in API requests. Token refresh is client-driven via a refresh endpoint, access tokens remain short-lived.

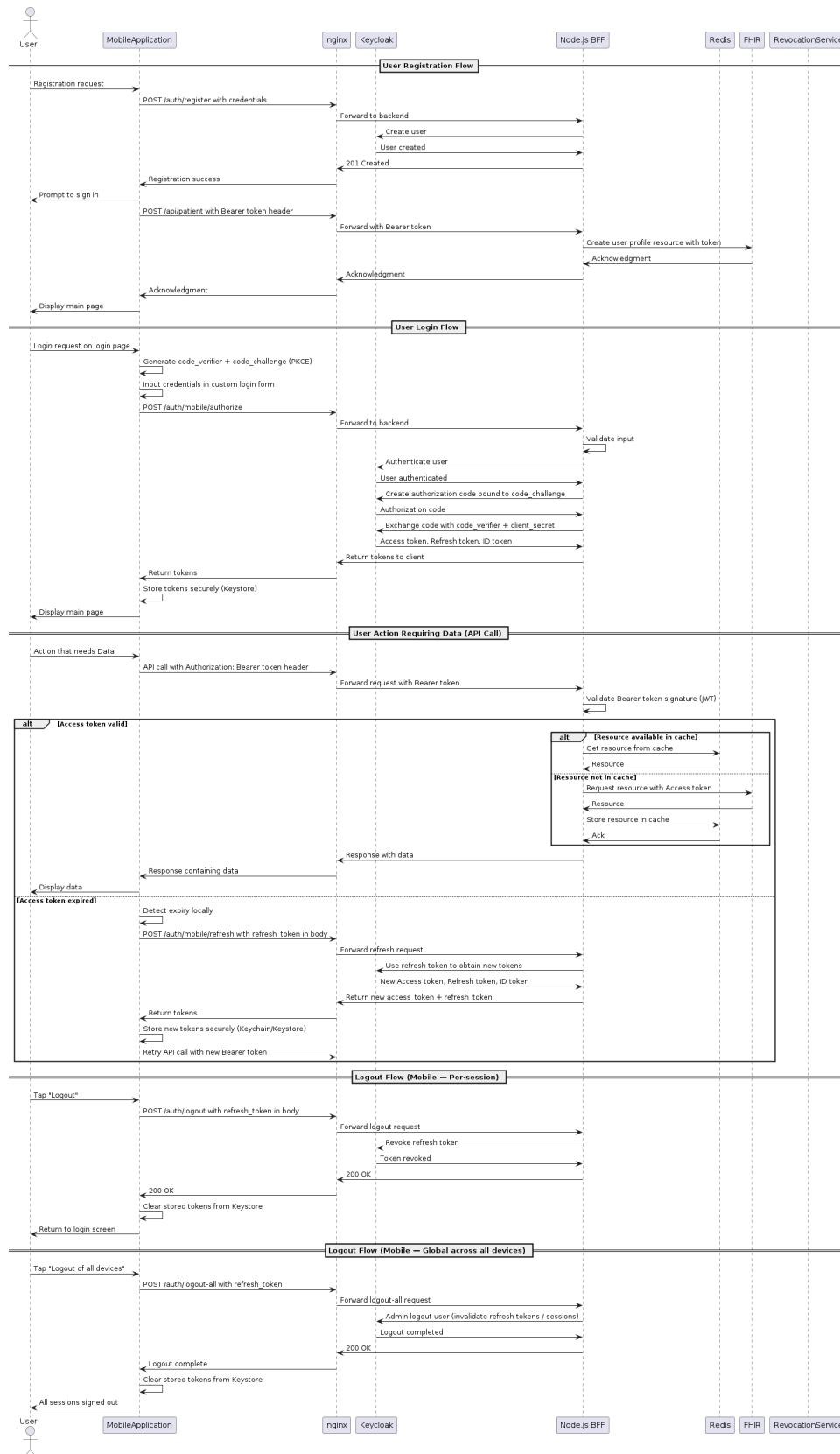


Figure 4.4: Mobile Token Authentication Flow (Future): BFF-mediated Authorization Code with PKCE, secure keystore token storage, and client-driven token refresh.

Session Storage

Browser sessions are maintained using express-session with RedisStore. The BFF saves access/refresh/ID tokens and their expirations. A refresh routine renews tokens when close to expiry. Session cookies are configured for Secure + HttpOnly, and SameSite according to deployment needs.

4.2.2 Authorization & Policy Enforcement

BFF Middleware: Session Check, JWT Verify, Scope Validation

- **Session check (requireSession method):** verifies presence of user and tokens in the Redis-backed session. Automatically refreshes expired tokens by calling Keycloak's token endpoint and persists the updated tokens back to Redis. Populates `req.accessToken`, `req.user`, and `req.kauth` for downstream middleware.
- **JWT verification (verifyToken method):** validates JWT signatures against Keycloak's JWKS endpoint, checks issuer (iss), audience (aud), algorithms, and clock skew tolerance. The Authorization header is populated by `attachForwardedToken` middleware, which extracts the session token from `req.accessToken` (set by `requireSession`) or request headers in general.
- **Scope checks (validateScopes method):** parses `scope` claim and `realm_access.roles` from the token. Compares required SMART on FHIR scopes (e.g., `patient/<id>.rs`) against token scopes using pattern matching. For patient-specific scopes, validates that the `patient` claim in the token matches the requested resource ID.

FHIR Server Enforcement

Future work: validate JWTs independently to implement defense in depth, leverage FHIR server's built-in SMART on FHIR policy enforcement for resource-level access control based on scopes and patient context.

4.2.3 Doctor–Patient Consent & Access Grants

The intended model supports patient-granted access for doctors, with grants stored in Redis (grant key, scopes, TTL) and mirrored as FHIR Consent resources. FHIR Consent resources are created with patient verification (2FA, PIN...) and include provisions specifying scoped access (duration for example). Access grants are cached in Redis for performance but the FHIR Consent is the authoritative source. The BFF verifies an active grant before calling FHIR for doctor requests. Future work: finalize consent persistence, link to FHIR Consent, and enforce patient binding in scope validation.

4.2.4 Session Management & Revocation

The BFF exposes logout endpoints:

- Per-session logout: destroys the current session in Redis and revokes refresh tokens at Keycloak's revoke endpoint.
- Global logout: removes all user sessions and revokes refresh tokens at Keycloak.

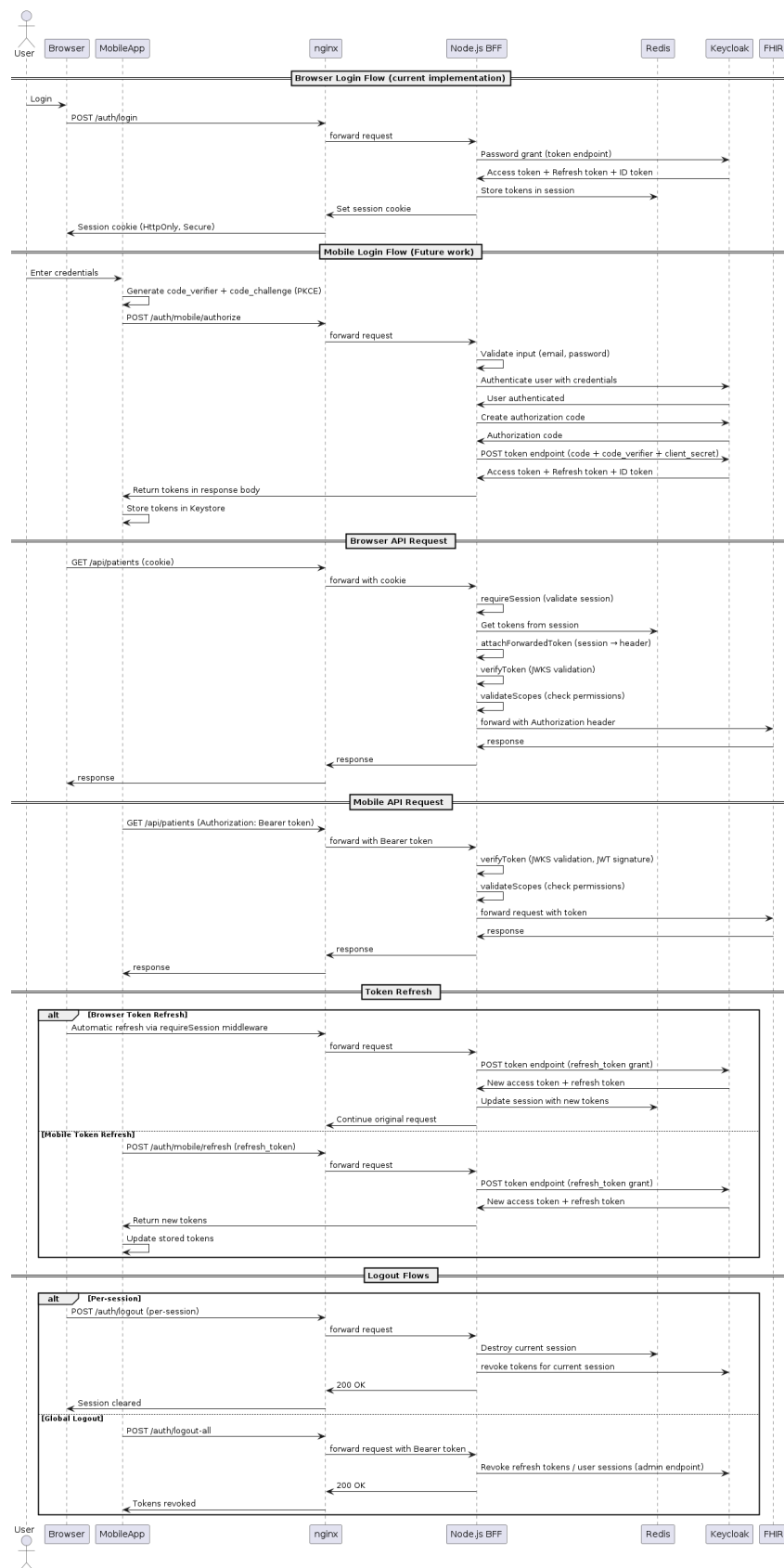


Figure 4.5: Token Flow Overview: Multi-client architecture (browser vs. mobile), session/token management, per-session and global logout patterns.

4.2.5 Defense-in-Depth

Edge

- Browser: session cookies with Secure, HttpOnly, SameSite attributes, route guards, HTTP interceptors for 401 handling.
- Mobile: secure token storage, bearer token auth, client-driven token refresh.

API Gateway (nginx)

- nginx terminates TLS (certs mounted in the container), forces HTTPS (80→443), and proxies `/api` and `/auth` to the BFF, and `/` to the Angular app.
- Forwarded headers are set for correct cookie and session handling.
- Future work: enable HSTS, add common security headers, and tune timeouts.

BFF

Input Validation & Rate Limiting All authentication endpoints (login, register) validate input using Joi schemas before processing. Login requires valid email and password (min 8). Register requires valid email, password with complexity (uppercase, lowercase, digit, min 8 chars), and full name (alphanumeric + spaces). Validation errors are returned as HTTP 400 with field-level details for client feedback.

Rate limiting is implemented via three Redis-backed limiters using `rate-limit-redis` middleware:

- **loginLimiter**: 5 attempts/10 minutes (production) or 100/10 minutes (development so we could keep testing the system).
Counts only failed attempts (`skipSuccessfulRequests: true`).
- **registerLimiter**: 3 attempts/hour (production) or 100/hour (development).
- **generalLimiter**: 100 attempts/10 minutes (production) or 1000/10 minutes (development). Applied globally to all API routes.

Exceeded limits return HTTP 429 (too Many Requests), protecting endpoints from credential enumeration and brute-force attacks.

Security Event Logging & Audit Trail All authentication events (LOGIN_SUCCESS, LOGIN_FAILURE, REGISTER, LOGOUT, LOGOUT_ALL) are logged to Redis sorted sets with timestamps and a 90-day retention period. Each audit log entry captures:

- Event type and timestamp (Unix epoch).
- User ID and email.
- Client IP address and User-Agent header.
- Request ID (UUID) for tracing.
- Metadata.

Audit logs are queryable by event type or by user, enabling security monitoring and forensic analysis.

Session Revocation & Logout The BFF tracks all active sessions for each user in Redis. Per-session logout (`/logout`) destroys the current session and revokes current session's tokens at Keycloak. Global logout (`/logout-all`) clears all stored sessions for the user, rendering all active tokens invalid at the BFF layer. The frontend can then redirect to (`/login`), ensuring re-authentication for subsequent operations.

Resource Server (FHIR Policies)

Future work:

- enforce JWT validation at FHIR server and apply scope and consent-based rules.
- codify patient-specific access constraints for doctor roles.

4.3 Implementation & Setup

4.3.1 Keycloak Configuration

Clients, Scopes

The BFF requests valid scopes. Keycloak is be configured to permit these scopes for the client based on the user's role and map these roles to appropriate SMART scopes.

Password Policy

Registration validates password complexity (length and character classes) in the BFF and matches Keycloak's password policy.

4.3.2 Backend-for-Frontend (BFF) Security Implementation

Session Middleware (Redis), Token Refresh, Token Rotation

Express-session with RedisStore persists session state, including user identity, access token, refresh token, ID token, and their expiration times. A refresh action runs in the `requireSession` middleware: when a token approaches expiration, the BFF automatically sends a refresh token grant to Keycloak's token endpoint, obtains a new access token, and persists the updated values back to Redis. This refresh is transparent to the frontend.

Session cookies are configured with:

- **Secure:** over HTTPS only
- **HttpOnly:** prevents JavaScript access, mitigating XSS token theft.
- **SameSite:** set to `Lax`, blocking CSRF attacks while allowing safe cross-site navigation.
- **MaxAge:** 1 hour so users must re-authenticate on the browser after inactivity.

JWT Verification (JWKS), Scope Checks, Patient Binding

JWKS-based verification validates token signatures using Keycloak's public key endpoint. Checks include:

- Signature validity (RS256 algorithm).
- Issuer claim (`iss`) matches Keycloak's realm URL.
- Audience claim (`aud`) includes the BFF's client ID.

Scope checks compare the token's `scope` claim against required route scopes using pattern-matching logic that handles wildcards. patient-specific scopes require the token's `patient` claim to match the requested resource Id.

Input Validation, Error Handling

All user input (login email, registration password, full name) is validated using Joi schemas before processing. Invalid requests return HTTP 400 with field-level error details, enabling the frontend to display specific guidance. Error responses explicitly do not leak sensitive system details, reducing information disclosure risks.

Mobile Authentication Endpoints (Future Work)

Three dedicated endpoints support mobile client authentication flows:

POST /auth/mobile/login: Authenticates against Keycloak using the Resource Owner Password grant. Upon success, returns `{access_token, refresh_token, id_token, expires_in, user}` in the response body. The mobile app stores these tokens in secure storage (Keystore) and includes the access token in subsequent API requests via **Authorization: Bearer <token>** headers. Rate limiting and input validation (Joi schemas) are enforced. Audit logged as `MOBILE_LOGIN_SUCCESS` or `MOBILE_LOGIN_FAILURE` to separate browser and mobile authentication for auditing granularity.

POST /auth/refresh Accepts `{refresh_token}` in the request body and exchanges it for a new access token via Keycloak's refresh token grant endpoint. Returns `{access_token, refresh_token, expires_in}`. Called client-side by the mobile app when the access token expires. Enables stateless token refresh. Audit logged as `TOKEN_REFRESH` or `TOKEN_REFRESH_FAILURE`.

POST /auth/logout (will be updated for mobile) Dual-path logout supporting both browser sessions and mobile bearer tokens. Mobile path: detects **Authorization: Bearer** header, revokes tokens at Keycloak (via revoke tokens endpoint), and returns `{ok: true}`. Browser path: uses `req.session`, destroys the session, and returns `{ok: true, logoutUrl}`. Requires `refresh_token` in body for Keycloak-side token revocation. Audit will also be logged with client type specified to enable distinction between logout types.

All three endpoints are protected by rate limiters and log to the audit trail for security monitoring.

4.3.3 nginx API Gateway

TLS Termination, HSTS, Secure Headers

TLS is terminated at nginx using valid certificates (self-signed for dev, will be CA-signed for production using Let's encrypt). HTTP traffic on port 80 is redirected to HTTPS (port 443) to ensure all data in transit is encrypted.

The BFF Express server is configured with Helmet, which sets security headers:

- **Content-Security-Policy (CSP):** restricts script sources to `'self'`, reducing XSS attack surface.
- **X-Frame-Options:** prevents clickjacking by restricting iframe embedding.
- **HSTS (Strict-Transport-Security):** forces HTTPS for 1 year, preventing downgrade attacks.

Proxy Configuration, Forwarded Headers

nginx proxies requests to the BFF ("/api" and "/auth" routes) and the Angular frontend ("/" route). The `trust proxy` setting is enabled in Express, allowing it to correctly interpret `X-Forwarded-For`, `X-Forwarded-Proto`, and other headers set by nginx. This ensures:

- Session cookies are correctly marked as Secure (based on proxied HTTPS connection).
- Client IP addresses are correctly logged for audit and rate-limiting purposes.
- Session affinity is maintained across the BFF cluster (when we implement cloud deployment and load balancing).

CORS Configuration

CORS is configured at the BFF level to accept requests only from the frontend origin. Credentials are included in cross-origin requests, allowing the browser to send session cookies. This prevents unauthorized external origins from accessing API endpoint.

4.3.4 Container Security & Deployment

Docker Compose orchestrates five security services: nginx (TLS gateway), Keycloak (identity provider), Postgres (user database), and two Redis instances (session store and audit log store). Security practices include:

- **Volume Mounts:** TLS certificates are mounted as read-only volumes from the host.
- **Network Isolation:** Services communicate over a private Docker network; Redis and Postgres are not exposed to external ports (only accessible from BFF and nginx).
- **Image Security:** we used official base images, most of them scanned for vulnerabilities (CVEs).

Future work: add resource limits per container, enable Docker user namespaces.

4.3.5 Frontend & Mobile Clients

Angular Frontend Architecture

The Angular frontend implements several security layers:

Route Guards (Authentication Check) Protected routes (dashboard, med-graph/:id) are guarded by `authGuard`, a route `canActivate` function that:

- Calls `AuthService.checkAuthStatus()` (a custom function that calls our BFF `auth/me` endpoint) at route activation.
- Verifies the response's `authenticated` flag.
- If authenticated, allows route access, otherwise redirects to `/login`.

The guard injection follows Angular's functional guard pattern (`CanActivateFn`), using dependency injection for `AuthService` and `Router`.

Authentication Interceptor (401 Handling) A global HTTP interceptor (`authInterceptor`) wraps all outbound HTTP requests:

- Catches HTTP responses with status code 401 (Unauthorized).
- Logs a warning message (`console.warn`) for debugging.
- Redirects to `/login`, clearing the current route and forcing re-authentication.
- Re-throws the error after routing, allowing components to handle error states.

This provides automatic session expiry handling: if the backend session expires or tokens are revoked, the first 401 response triggers a redirect, preventing continued access to stale sessions.

Credentials Handling (withCredentials Flag) All HTTP requests to auth endpoints (`/login`, `/register`, `/me`, `/logout`, `/logout-all`) include `withCredentials: true`, instructing Angular's HTTP client to:

- Send session cookies with cross-origin requests.
- Receive Set-Cookie headers from the backend.

This enables secure session management via HTTP-only cookies, preventing token exposure in `typescript`.

Error Handling & User Feedback The `AuthService`'s `handleError` method extracts backend error details:

- For HTTP errors with a `details` array (validation errors from the BFF), displays field-specific messages.
- For generic server errors, displays a fallback message ("Server error").
- Logs errors to the browser console for debugging.

Components using `AuthService` subscribe to the returned `Observable` and display errors to users, improving UX on failed login/registration.

Current User State Management The AuthService maintains a BehaviorSubject<currentUser> observable:

- Populated on successful login, registration, or checkAuthStatus.
- Cleared on logout or failed authentication.
- Subscribed to by components to display user info (name, email) and show/hide UI elements based on auth state.
- Provides a reactive interface: any component injecting AuthService can subscribe to currentUser\$ and react to state changes.

Third-Party Dependencies Future work: Pin exact versions in package.json and regularly audit for vulnerabilities (using npm audit).

Mobile App (Flutter) Security Architecture

Although not yet fully implemented, the planned mobile architecture includes:

- **Secure Token Storage:**
 - Android: Keystore system.
- **Bearer Token Auth:** Each HTTP request includes Authorization: Bearer <access_token> header.
- **Token Refresh Logic:** Mobile app implements its own refresh routine (unlike browser, where the BFF handles refresh):
 - On 401 response, call the BFF's token refresh endpoint.
 - Retry the original request with the new token.
 - If refresh fails, clear tokens and redirect to login.
- **Certificate Pinning** (future work): pin the BFF's TLS cert in the mobile app to prevent MITM attacks by rogue CAs.

Environment-Specific Configuration

The frontend uses two environment files:

- `environment.ts` (development): `production: false, apiUrl: '/api', authUrl: '/auth'`. Uses relative paths, which resolve to the development server or proxied backend.

- `environment.prod.ts` (production): `production: true, apiUrl: '', authUrl: ''`. URLs are currently empty to be populated at deployment time.

This allows the same compiled app to be deployed across environments by injecting the correct API endpoints at runtime (future work: implement environment variable injection at container startup).

4.3.6 Angular Frontend Security Implementation

Route Protection & Guards

All protected routes (dashboard, med-graph/:id) are declared with `canActivate: [authGuard]`. The `authGuard` executes before route activation and checks authentication status by calling the BFF's GET `/auth/me` endpoint. If the request returns `authenticated: false` or fails with 401, the guard redirects to `/login` and cancels route activation. This prevents unauthorized access to protected pages even if a user manually navigates via URL bar.

HTTP Interceptors & 401 Handling

The global `authInterceptor` catches 401 responses from any API endpoint. Upon 401, the interceptor:

- Logs the unauthorized attempt.
- Immediately navigates to `/login`.
- Re-throws the error, allowing components to also react.

This provides a safety net: even if a route guard passes, if the session expires during navigation, the 401 interceptor ensures the user is redirected to re-authenticate.

Cookie-Based Credentials

All auth endpoints use `withCredentials: true`, ensuring the Angular HTTP client:

- Sends session cookies with every request.
- Accepts Set-Cookie headers from the BFF.

Reactive State Management

The `AuthService` uses a `BehaviorSubject` to maintain observable current user state. Any component can subscribe to `currentUser$` and react to authentication changes.

Error Transparency

Backend validation errors (from /register endpoint) include field-level details in the HTTP response's `error.details` array. The AuthService's `handleError` method extracts and formats these messages, allowing the login component to display specific guidance. This improves UX and helps users follow password complexity requirements.

4.3.7 Keycloak

Keycloak serves as the OpenID Connect identity provider. It manages user accounts, issues JWT tokens (access, refresh, and ID tokens), maintains public JWKS endpoints for token verification, and supports role-based access control via realm roles and client roles. In the current setup, the BFF uses the Resource Owner Password grant to obtain tokens on behalf of users.

4.3.8 Redis

Two Redis instances are deployed:

- **Session Store:** backing store for express-session. Persists user sessions, access tokens, refresh tokens, and their expiration times with a 1-hour TTL.
- **Audit Store:** persists authentication events (LOGIN_SUCCESS, LOGIN_FAILURE, REGISTER, LOGOUT, LOGOUT_ALL) as sorted sets. Each entry includes timestamp, user ID, IP, User-Agent, and request ID. Entries expire after 90 days.

Redis also stores user session tracking sets (all session IDs for each user) to enable logout-all operations.

4.3.9 nginx API Gateway

Acts as the TLS termination point, HTTP-to-HTTPS redirect, and reverse proxy. Sets forwarded headers for correct handling of session cookies and client IP logging in the BFF.

4.3.10 PostgreSQL

Keycloak's backing database, storing user accounts, roles, and credentials.

4.3.11 Node.js Backend-for-Frontend (BFF) Libraries

- **express-session and connect-redis**: Server-side session management with Redis persistence, enabling stateful auth for browsers.
- **joi**: Schema validation library for login and registration input (email format, password complexity, full name pattern).
- **rate-limit-redis**: Rate limiting middleware backed by Redis. Protects endpoints from brute-force attacks.
- **jsonwebtoken**: JWT creation and verification library (for validation via JWKS).
- **jwtks-rsa**: Fetches and caches Keycloak's public JWKS endpoint. Automatically refreshes keys on signature validation failure.
- **axios**: HTTP client for outbound calls to Keycloak API.
- **helmet**: Express middleware that sets security headers
- **cors**: Middleware for Cross-Origin Resource Sharing, configured to accept requests from the Angular frontend origin only.

4.4 Challenges & Trade-offs

4.4.1 Session Management Across Client Types

Browsers use server-side sessions with secure cookies, mobile apps use bearer tokens in the Authorization header. Keeping behavior consistent requires:

- Route guards and 401 interceptors on both client types.
- Unified token refresh logic (automatic for browser via `requireSession`, manual for mobile via OAuth refresh endpoint).
- Synchronized revocation: per-session logout on the BFF invalidates tokens server-side, mobile clients must also clear cached tokens locally.

4.4.2 Stateless Tokens vs. Revocation Needs

Access tokens are stateless (signed by Keycloak, verified locally), making them scalable. However, true instant revocation (logout-all) for browsers requires server-side state (Redis session tracking). The current design trades off stateless simplicity for revocation correctness: the BFF maintains session state and validates session presence on every request, also for bearer token users in future deployments.

4.4.3 Balancing Consent Privacy & Usability

Patient-granted access for doctors (consent workflow) must be enforced transparently. Overly strict consent checks may block legitimate clinical workflows, overly permissive checks may expose PHI. The current design is for grants to be stored in Redis (grant key, scopes, TTL) and validated at the BFF, and the FHIR server will apply additional constraints based on consent resources.

4.4.4 Clock Skew & Distributed Verification

JWT validation includes clock skew tolerance (10 seconds) to account for distributed clock drift between Keycloak and the BFF. However, if system clocks drift beyond this window or if Keycloak's keys rotate, validation failures may spike.

4.5 Security Analysis

4.5.1 Attack Surface Analysis

- **Token Theft:** mitigated by storing tokens server-side' not in browser memory. HTTP-only cookies prevent JavaScript access via XSS. TLS prevents interception in transit.
- **Cross-Site Request Forgery:** Session cookies use SameSite=Lax, blocking cross-site submissions. POST endpoints on the BFF do not rely solely on cookies.
- **Credential Enumeration / Brute-Force:** Rate limiters make password guessing infeasible within the policy window.
- **Information Disclosure:** Error messages do not leak system internals, where registration validation errors are field-level and generic. Audit logs are server-side and not exposed to unauthenticated clients.
- **Privilege Level:** Token claims are issued by Keycloak and validated server-side. The BFF doesn't allow clients to modify claims.
- **Patient Privacy Breach:** Scope checks enforce patient binding so doctors cannot access patients without appropriate scopes/consents. FHIR server applies additional resource-level checks.

4.5.2 Threat Model & Residual Risks

Residual risks include:

- **Keycloak Compromise:** If Keycloak is breached, all issued tokens become untrustworthy. Mitigated by: securing Keycloak (strong admin passwords, HTTPS only), and monitoring for unusual token patterns.
- **Denial of Service (DoS):** Backend could be overwhelmed by excessive requests. Mitigated by: rate limiters on API endpoints.
- **XSS Attacks:** While tokens are not in browser memory, XSS could still hijack sessions via cookies. Mitigated by: CSP headers, HttpOnly cookies
- **Credential Leakage:** Users reusing weak passwords across sites risk credential stuffing attacks. Mitigated by: strong password policies, rate limiting, and future MFA implementation.
- **Keycloak's Storage of Credentials:** If Keycloak's database is compromised, user credentials may be exposed. Mitigated by: securing Postgres access, Future work: encryption at rest.
- **Redis Compromise:** Session and audit stores in Redis are unencrypted at rest. Mitigated by: network isolation and future work on Redis encryption.
- **Scope/Role Misconfiguration:** Overly broad scopes or clinician roles may grant unintended access. Mitigated by: audit logging, Future work: more granular access control through keycloak authorization functionalities.
- **Consent Enforcement Gaps:** Current consent model is incomplete, doctor-patient consent is not fully enforced at the FHIR server. Mitigated by: future work on FHIR Consent resources and server-side validation.

4.5.3 Mitigations Implemented & Gaps

Implemented Mitigations

- TLS encryption for all data in transit.
- Session cookies with HttpOnly, Secure, and SameSite flags.
- JWKS-based JWT verification with issuer, audience, and algorithm checks.
- Rate limiting on authentication endpoints (adaptive for dev/prod).
- Input validation for authentication data.
- Audit logging.
- User session tracking for per-session and global logout.
- Security headers via Helmet.

Gaps & Future Work

- **PKCE (Proof Key for Code Exchange)**: Current flow uses Resource Owner Password grant, future work will migrate to Authorization Code + PKCE for improved security.
- **Consent Enforcement**: Patient-granted doctor access is not yet implemented or persisted as FHIR Consent resources or validated at the FHIR server.
- **Redis Encryption**: Session and audit data in Redis are unencrypted at rest, future work includes enabling Redis persistence encryption.
- **Centralized Audit Dashboard**: Audit logs are stored in Redis, future work includes creating a dedicated UI for viewing and filtering logs as that would improve security monitoring (low priority future work).
- **Scope / Role Mapping**: Keycloak role-to-SMART-scope mapping needs formalization and documentation.
- **Additional Headers**: CSP and HSTS are implemented; future work includes adding X-Content-Type-Options, Referrer-Policy, and Permissions-Policy.

4.6 Summary

CFI-Care implements a defense-in-depth security architecture across three layers:

Identity & Access (Keycloak + Tokens) OAuth 2.0 with the Resource Owner Password grant issues JWTs signed by Keycloak. Tokens include user identity, scopes, roles, and claims. Keycloak serves as the trusted identity provider, issuing and validating credentials.

Browser Access (Sessions + BFF) The BFF stores tokens server-side in Redis-backed sessions, exposing only secure, HTTP-only cookies to the browser. A per-request token refresh routine ensures tokens never expire, transparently re-authenticating users. This design protects tokens from XSS theft and simplifies client-side logic.

API Layer (Middleware + Validation) Every API request flows through multiple middleware checks: session validation, JWT signature verification, and scope/role enforcement. Rate limiters protect endpoints from brute-force attacks. Input validation prevents injection attacks. Audit logs capture all authentication events for forensic analysis.

Transport & Edge (TLS + Headers) nginx terminates TLS, enforces HTTPS-only access, and sets forwarded headers. The BFF applies Helmet security headers (CSP, HSTS, X-Frame-Options)

Current State The implementation is functional and ready for incremental hardening:

- All authentication endpoints are secured with rate limiting and input validation.
- Token refresh is automatic and transparent to browsers.
- Per-session and global logout are fully functional.
- Audit trails are captured and retained for 90 days.
- Mobile support is architected for bearer token auth (future implementation).

Chapter 5

AI Integration

Chapter 6

Testing and Verification

6.1 Backend Testing Overview

This section details the automated testing effort for the Node.js backend. The suite is built on Jest with Supertest for HTTP contract checks. Controllers, services, HTTP clients (axios), Redis, and PostgreSQL clients are mocked to isolate behavior where appropriate, while targeted integration tests hit real Redis and Postgres instances when available. Test data favor minimal synthetic fixtures to keep runs deterministic.

6.1.1 Execution Environment

The suite runs on Node.js with Jest and Supertest; axios, Redis, and Postgres clients are typically mocked, while Redis/Postgres integration tests execute when the backing services are reachable via `REDIS_URL` and `PATIENTS_DB_*`. Network calls are isolated in most suites, IDs and payloads are fixed for determinism, and database inserts clean up after themselves.

6.1.2 Scope

Coverage spans HTTP route contracts for patients, encounters, binary resources, and history-graph APIs; service-layer FHIR interactions and caching; Joi-based validation middleware; Redis caching helpers with TTLs; Postgres connectivity and timeline graph persistence; and end-to-end workflows linking patient creation, related-data retrieval, and graph operations.

6.1.3 API Route Coverage

Route tests exercise patient CRUD, TOON export, and related-data bundles; encounter fetch and ‘\$everything’ retrieval with create-by-id; binary PDF fetch/create/delete with required-field validation; and history-graph initialization, head-node creation, CRUD, seeding, and empty-graph handling.

6.1.4 Service and Integration Tests

Patient service specs cover cache-first reads with Redis, FHIR fallbacks, 404 and connectivity errors, create flows (with or without client-specified IDs), and ‘\$everything’ bundles. Condition service specs target patient-scoped queries, empty bundles, and create/update with explicit IDs. History graph service tests remain scaffolded—node/edge CRUD, caching, validation, and FHIR/EOC integration are outlined but still lack concrete assertions.

6.1.5 Test Design and Data

Positive-path cases walk through patient/encounter/condition creation, retrieval, and related-data aggregation, including binary uploads and graph growth. Negative-path cases cover Joi validation failures, cache misses, 404s from FHIR, connection failures, missing IDs, invalid graph categories, and empty bundles. Axios and cache helper calls are stubbed per test to keep contracts deterministic; the graph service uses a mocked pg client. Transient IDs such as `node-001` or `pat-e2e-001` repeat across tests, and Postgres inserts are cleaned up to avoid residue.

6.1.6 End-to-End Workflows

The patient workflow proceeds as create → fetch → add condition → related-data retrieval, asserting state consistency. The history-graph workflow initializes an EOC/graph, creates the head node, grows child nodes (with updates and deletes), verifies branching, and exercises cache-aware readbacks, including invalid-category rejection.

patient-workflow.e2e (Pass)



historyGraph-workflow.e2e (Pass)



Figure 6.1: Graph view of the two end-to-end suites; edges align to assertions within each test.

6.1.7 Validation and Middleware

Joi schemas enforce required patient fields, formats, and length constraints while permitting extra fields. The request-validator middleware is exercised on both happy-path forwarding and failure-path messaging.

6.1.8 Caching and Redis

Cache helper tests span get/set/delete semantics, TTL handling, error tolerance, and patient cache invalidation (Redis mocked). Redis integration tests, when enabled, hit a live instance to confirm CRUD, TTL expiry, and support for strings, lists, and sets via `REDIS_URL_PATIENTS`.

6.1.9 Database Checks

Postgres smoke tests confirm connectivity, the presence of `timeline_nodes` and `node_edges`, and insert/select round-trips with cleanup. A standalone probe script inspects timeline nodes and edges to sanity-check graph visualization data.

6.1.10 Gaps and Next Steps

1. Add concrete assertions to history graph service integration tests (node/edge creation, validation, cache invalidation, FHIR/EOC fallbacks).
2. Extend end-to-end negative paths for encounters and conditions, aligning status codes and error bodies.
3. Add contract tests to lock TOON export and ‘\$everything’ bundle payload shapes.
4. Document and script external dependencies (Redis, Postgres, FHIR stubs) for reliable CI execution.

6.1.11 Test Result Summary

Figures 6.2 and 6.3 summarize the principal suites and their last known status.

6.1.12 Interpretation of Results

- Core HTTP surface for patients, encounters, binaries, and history graph is green, indicating stable contracts at the controller/route layer.

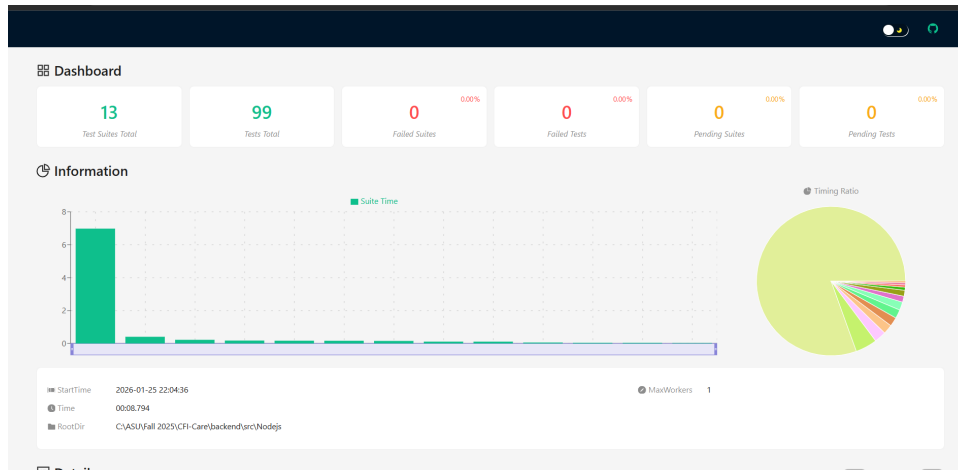


Figure 6.2: Number of Test Cases and its status.

File	ExecTime	Status	Action
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_vedis.test.js	00:06.980	All Passed 5 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_v2e\patient-workflow.e2e.test.js	00:00.407	All Passed 2 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_historyGraphRoutes.test.js	00:00.223	All Passed 10 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_binaryRoutes.test.js	00:00.169	All Passed 8 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientRoutes.test.js	00:00.177	All Passed 8 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_historyGraphService.integration.test.js	00:00.154	All Passed 30 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_vencounterRoutes.test.js	00:00.164	All Passed 3 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_v2e\historyGraph-workflow.e2e.test.js	00:00.111	All Passed 4 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_cacheHelper.test.js	00:00.112	All Passed 8 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientService.integration.test.js	00:00.058	All Passed 9 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientValidation.test.js	00:00.043	All Passed 7 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_validateRequest.test.js	00:00.041	All Passed 8 ✓	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_conditionService.integration.test.js	00:00.029	All Passed 4 ✓	

Figure 6.3: Unit, integration and End-to-end workflow suite status.

- Service-layer caching and FHIR interaction paths are exercised with both cache hits and misses; error handling for 404 and connectivity is verified.
- Live-environment checks for Redis/Postgres pass when backing services are reachable; mark these as conditional (Pass*).
- The main gap is the history graph service integration file, which outlines scenarios but lacks assertions; adding those will close coverage on graph business logic.

Chapter 7

Conclusion and Future Work

7.1 Conclusion

7.2 Future Work

7.2.1 Security

Next Steps

- Implement mobile client authentication endpoints.
- Deploy secrets management using a vault solution
- Deploy security containers to cloud infrastructure with load balancing.
- Use Let's Encrypt for production level TLS certificates after cloud deployment.
- Complete the patient-doctor consent workflow and enforce it at the FHIR server.
- Finalize role-to-scope mapping in Keycloak and document SMART on FHIR compliance.
- Migrate to Authorization Code + PKCE for improved security and standards compliance.
- Build a centralized audit dashboard for security monitoring.
- Enable Redis persistence encryption for session and audit data at rest.

Appendix

Appendix A

Lists

List of Figures

1.1	Evolution of HL7 Standards from Messaging to RESTful Resources. . . .	4
1.2	Visual Comparison of Data structure: HL7 v2 Message vs. FHIR JSON Resource.	6
3.1	High-Level Container Architecture showing the interaction between the Nginx proxy, application services, and data persistence layers.	11
3.2	Internal layered architecture of the Node.js Application Server, detailing the middleware stack and service distribution.	12
3.3	Entity-Relationship Diagram (ERD) illustrating the integration of custom graph tables with the standard FHIR resource table.	14
3.4	Request/Response flow for patient data retrieval, showing cache hit and miss scenarios with complete middleware pipeline.	16
3.5	Complete encounter creation workflow showing FHIR resource persistence, graph construction, and cache invalidation cascade.	18
3.6	Example Patient History Graph showing a diabetes patient with concurrent hypertension, demonstrating temporal branching and multiple relationship types.	24
3.7	Two-Tier Caching Architecture showing distinct strategies for standard FHIR resources (Tier 1) and complex graph structures (Tier 2).	31
4.1	Security Architecture Components: Edge clients (Browser, Mobile), API Gateway (nginx), Backend-for-Frontend (Node.js), Identity & Storage (Keycloak, Redis, Postgres), and Resource Server (HAPI FHIR) with their security-focused interactions.	38
4.2	Browser Token Authentication Flow: User registration, login, and API request handling with session cookies.	40
4.3	Planned Browser Flow (Future): Registration with email verification and BFF-mediated credential login, session cookie issuance, and server-side token refresh.	41

4.4	Mobile Token Authentication Flow (Future): BFF-mediated Authorization Code with PKCE, secure keystore token storage, and client-driven token refresh.	42
4.5	Token Flow Overview: Multi-client architecture (browser vs. mobile), session/token management, per-session and global logout patterns.	45
6.1	Graph view of the two end-to-end suites; edges align to assertions within each test.	62
6.2	Number of Test Cases and its status.	64
6.3	Unit, integration and End-to-end workflow suite status.	64

References

- [1] Grand View Research, *Digital Health Market Size, Share & Trends Analysis Report By Technology, By Component, By Region, And Segment Forecasts, 2025 - 2030*, <https://www.grandviewresearch.com/industry-analysis/digital-health-market>, Accessed: 2025-04-04.
- [2] Intellisoft, *FHIR vs. HL7: Core Differences & Standards Comparison*, <https://intellisoft.io/comparing-hl7-vs-fhir-core-differences/>, Accessed: 2025-04-04.
- [3] University of Porto Repository, *Interoperability in Healthcare Systems (Thesis/Dissertation)*, <https://repositorio-aberto.up.pt/bitstream/10216/164181/2/700384.pdf>, Accessed: 2025-04-04.
- [4] Wikipedia, *Fast Healthcare Interoperability Resources*, https://en.wikipedia.org/wiki/Fast_Healthcare_Interoperability_Resources, Accessed: 2025-04-04.
- [5] HL7 International, *FHIR HL7 Documentation*, <https://www.hl7.org/fhir/>, Accessed: 2025-04-04.
- [6] HL7 International, *FHIR R4 Consent Resource*, <https://www.hl7.org/fhir/consent.html>, Accessed: 2025-11-04.
- [7] HL7 SMART on FHIR Community, *SMART App Launch Framework: Secure, Standardized, Data-Driven Application Architecture for Biomedicine*, <http://www.hl7.org/fhir/smart-app-launch/>, Accessed: 2025-09-15.
- [8] OpenID Foundation, *OpenID Connect Core 1.0*, https://openid.net/specs/openid-connect-core-1_0.html, Accessed: 2025-08-28.
- [9] D. Hardt (Editor), *The OAuth 2.0 Authorization Framework*, RFC 6749, Internet Engineering Task Force (IETF), October 2012, <https://tools.ietf.org/html/rfc6749>, Accessed: 2025-08-28.
- [10] B. Jones and D. Hardt (Editors), *The OAuth 2.0 Bearer Token Usage*, RFC 6750, Internet Engineering Task Force (IETF), October 2012, <https://tools.ietf.org/html/rfc6750>, Accessed: 2025-01-15.

- [11] M. Jones, J. Bradley, and N. Sakimura, *JSON Web Token (JWT)*, RFC 7519, Internet Engineering Task Force (IETF), May 2015, <https://tools.ietf.org/html/rfc7519>, Accessed: 2025-08-28.
- [12] O. Steele and A. Parecki (Editors), *OAuth 2.0 Security Best Current Practice*, RFC 9700, Internet Engineering Task Force (IETF), October 2024, <https://tools.ietf.org/html/rfc9700>, Accessed: 2025-11-04.
- [13] M. Bertocci, *OAuth 2.0 Token Mediator Pattern for Web API Authorization*, Internet-Draft draft-bertocci-oauth2-tmi-bff-01, IETF, 2023, <https://tools.ietf.org/html/draft-bertocci-oauth2-tmi-bff-01>, Accessed: 2025-01-14.
- [14] S. Bingle, Ed. *HTTP State Management Mechanism*, RFC 6265, Internet Engineering Task Force (IETF), April 2011, <https://tools.ietf.org/html/rfc6265>, Accessed: 2025-08-30.
- [15] N. Sakimura, J. Bradley, and N. Agarwal, *Proof Key for Public OAuth 2.0 Authorization Code Flow (PKCE)*, RFC 7636, Internet Engineering Task Force (IETF), September 2015, <https://tools.ietf.org/html/rfc7636>, Accessed: 2025-09-30.
- [16] D. Recordon (Editor) and D. Hardt (Editor), *OAuth 2.0 Threat Model and Security Considerations*, RFC 6819, Internet Engineering Task Force (IETF), January 2013, <https://tools.ietf.org/html/rfc6819>, Accessed: 2025-11-04.
- [17] OWASP Foundation, *OWASP Top 10 - 2021: The Ten Most Critical Web Application Security Risks*, <https://owasp.org/Top10/2021/>, Accessed: 2025-09-30.
- [18] OWASP Foundation, *OWASP API Security Top 10*, <https://owasp.org/www-project-api-security/>, Accessed: 2025-11-02.
- [19] Keycloak Community, *Keycloak Documentation: Open Source Identity and Access Management*, <https://www.keycloak.org/documentation.html>, Accessed: 2025-08-20.
- [20] Keycloak, *Keycloak Server Administration Guide and Reference*, https://www.keycloak.org/docs/latest/server_admin/, Accessed: 2025-08-20.
- [21] Adam Baldwin and Contributors, *Helmet: Secure Express Apps by Setting Various HTTP Headers*, <https://helmetjs.github.io/>, Accessed: 2025-01-15.
- [22] OWASP Foundation, *Cross-Site Scripting (XSS) Prevention Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html, Accessed: 2025-09-30.
- [23] OWASP Foundation, *Cross-Site Request Forgery (CSRF) Prevention Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html, Accessed: 2025-09-29.

- [24] NGINX Inc., *NGINX Documentation*, <https://nginx.org/en/docs/>, Accessed: 2025-10-04.
- [25] Olivier Poitrey, *rate-limit-redis: Redis-backed Rate Limiting Middleware for Express*, <https://www.npmjs.com/package/rate-limit-redis>, Accessed: 2025-01-15.
- [26] hapi Framework Community, *Joi: Object Schema Validation*, <https://joi.dev/>, Accessed: 2025-01-15.
- [27] OWASP Foundation, *Logging Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html, Accessed: 2025-10-04.
- [28] U.S. Department of Health and Human Services, *HIPAA Security Rule*, <https://www.hhs.gov/hipaa/for-professionals/security/index.html>, Accessed: 2025-08-23.
- [29] Art Future, *OAuth 2.0 Authentication with Keycloak in Flutter Applications*, <https://medium.com/@art.futurx/oauth-2-0-authentication-with-keycloak-in-flutter-applications-35d588b2246d>, Accessed: 2025-12-04.
- [30] D. Denniss, C. Dodson, and W. Mills, *OAuth 2.0 for Native Apps*, RFC 8252, Internet Engineering Task Force (IETF), October 2017, <https://www.rfc-editor.org/rfc/rfc8252#section-8.12>, Accessed: 2025-12-04.
- [31] OWASP Foundation, *OWASP Mobile Top 10*, <https://owasp.org/www-project-mobile-top-10/>, Accessed: 2025-08-23.
- [32] OWASP Foundation, *OWASP Mobile Application Security (MAS)*, <https://mas.owasp.org/>, Accessed: 2025-08-23.
<https://developer.android.com/privacy-and-security/keystore>
- [33] Google, *Android Keystore System*, <https://developer.android.com/privacy-and-security/keystore>, Accessed: 2025-01-14.
- [34] Auth0, *The Backend-for-Frontend Pattern*, <https://auth0.com/blog/the-backend-for-frontend-pattern-bff/>, Accessed: 2025-12-04.
- [35] Sam Newman, *Backend-for-Frontend Architecture Pattern*, <https://samnewman.io/patterns/architectural/bff/>, Accessed: 2025-12-04.
- [36] Keycloak, *Keycloak Securing Applications and Services Guide*, <https://www.keycloak.org/guides.html#securing-apps>, Accessed: 2025-09-10.
- [37] Keycloak, *Keycloak REST API Documentation*, <https://www.keycloak.org/docs-api/latest/rest-api/index.html>, Accessed: 2025-09-10.

- [38] Keycloak, *Keycloak Authorization Services Guide*, https://www.keycloak.org/docs/latest/authorization_services/index.html, Accessed: 2025-09-10.
- [39] Keycloak, *Keycloak Server in Containers*, <https://www.keycloak.org/server/containers>, Accessed: 2025-09-10.
- [40] Keycloak Documentation, *Administering Sessions in Keycloak*, https://wjlw465150.gitbooks.io/keycloak-documentation/content/server_admin/topics/sessions/administering.html, Accessed: 2025-01-14.